

Operating Detection and Preventative Measures

Objectives

- Examine firewalls and next-generation intrusion detection systems (IDSs)/intrusion prevention systems (IPSs)
- Compare whitelisting and blacklisting
- Describe third-party security services, sandboxing, honeypots, and honeynets
- Know about antimalware
- Learn about machine learning (ML) and AI-based tools
- Describe patch and vulnerability management

Firewalls

- A firewall is a metaphor representing software and/or hardware controls that can limit the damage spreading from one subnet, virtual local area network (VLAN), zone, or domain to another
- It is typically deployed as a barrier (zone interface point) between an internal (trusted) network and an external (untrusted) network
- They are integrated systems of threat defense functioning at layers 2-7 and can be categorized as network or application firewalls



Next Generation Firewall Features

1

Layer 5-7 policies – deep packet inspection (DPI) or application visibility and control (AVC)

2

Authentication proxies – software-defined perimeter (SDP) access gateways

3

Identity services front-end for identity management (IdM) and 802.1X PNAC

Next Generation Firewall Features

4

Integrated IDS and IPS sensors

5

Unified threat management with data loss prevention (DLP)

6

Advanced malware protection
(cloud-based)

Next Generation Firewall Features

7

URL and content filtering

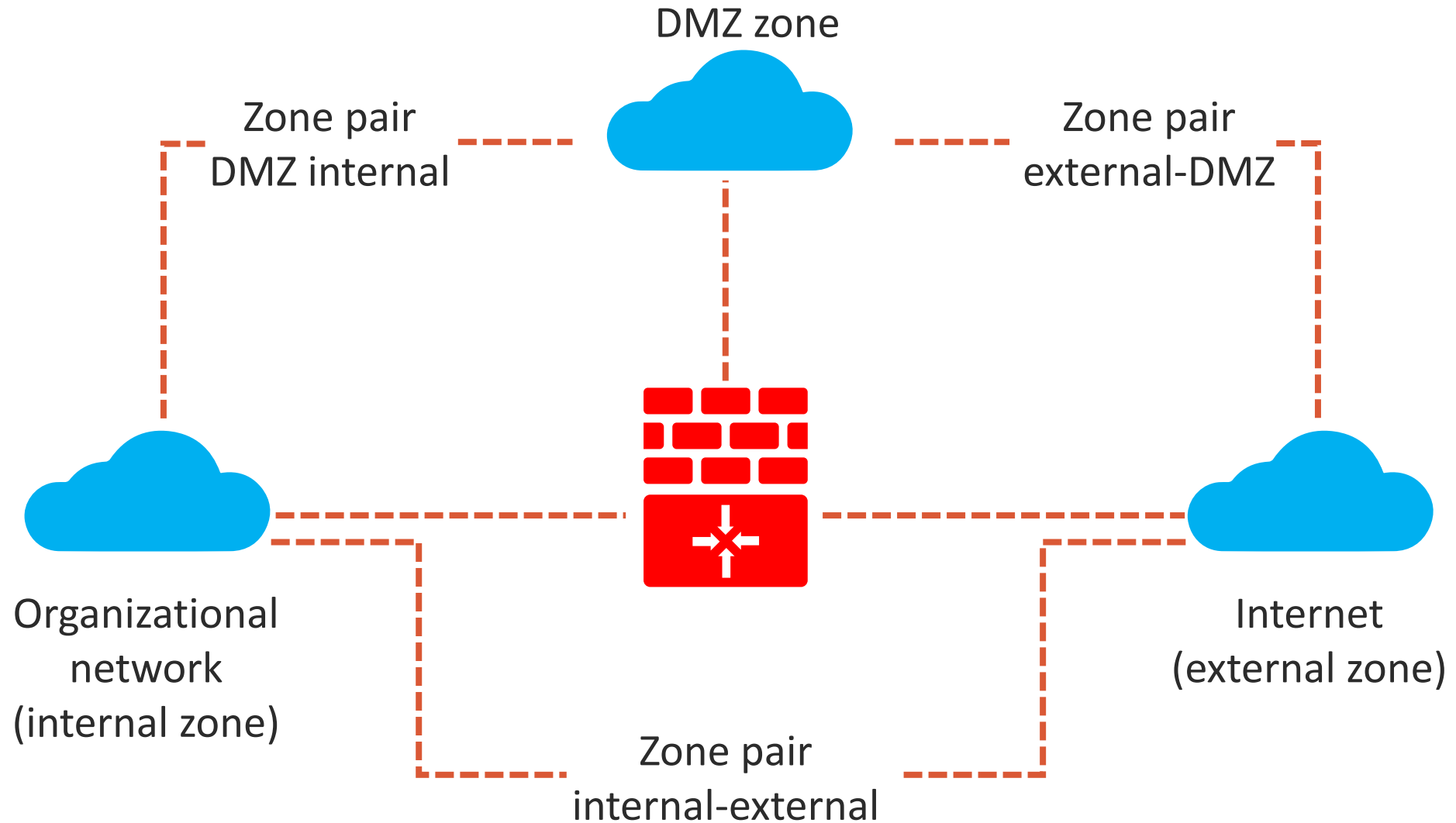
8

Botnet filtering for active defense

9

Cloud correlation and reputation filtering

Zone-based Firewalls

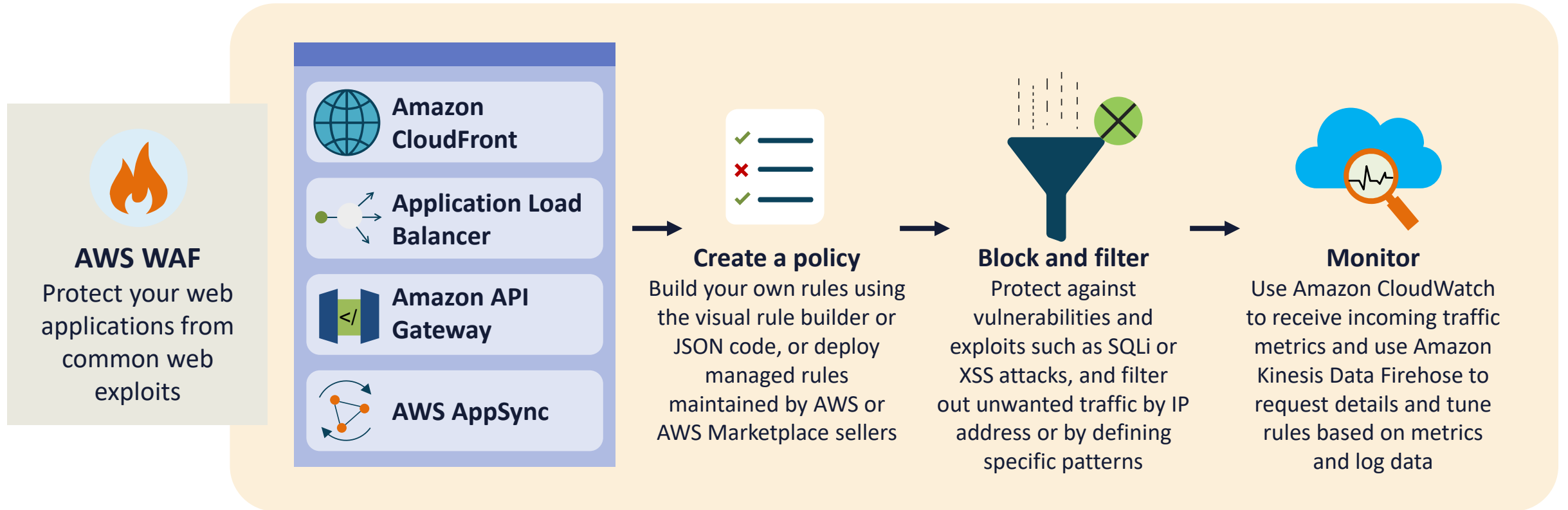




Web Application Firewall (WAF)

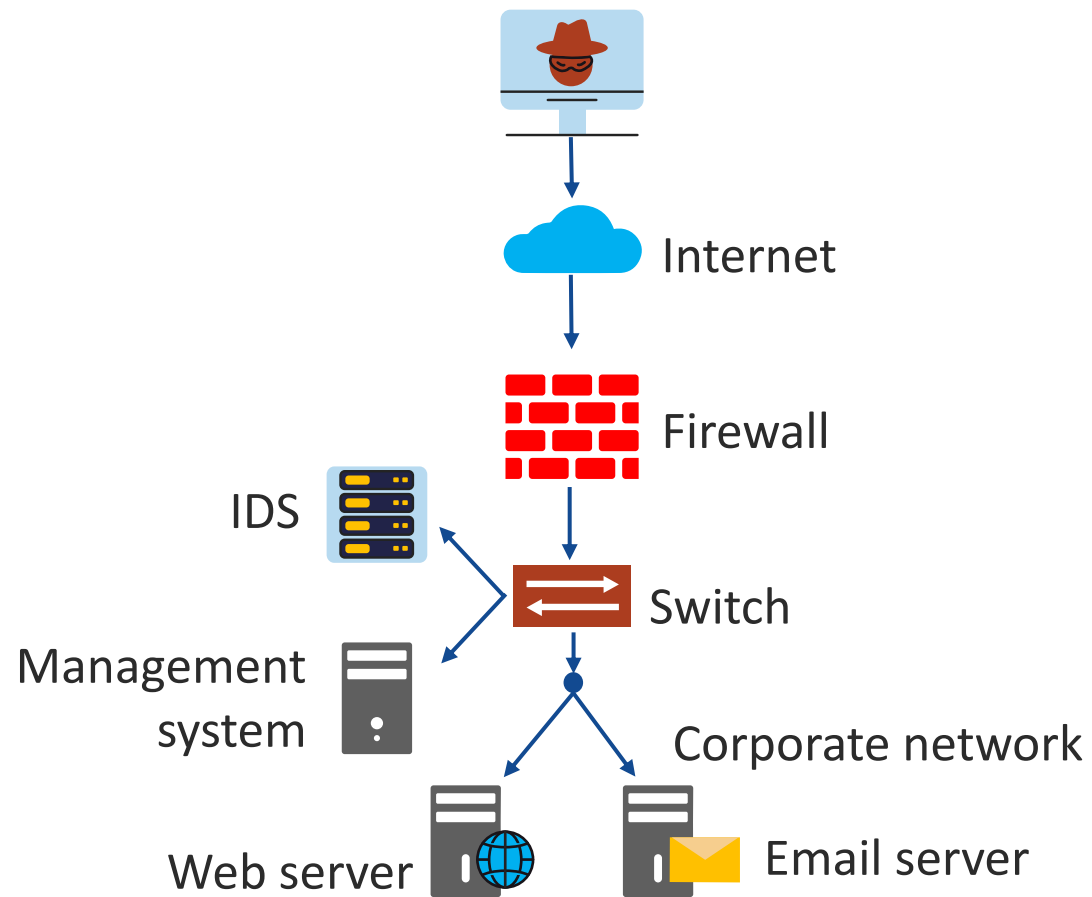
- Also called a web security gateway, these are appliances (usually virtual), server plugins, or filter engines that apply a set of rules (web access control lists) to an HTTP or HTTPS conversation
- These rules cover common OWASP Top 10 web attacks like cross-site scripting (XSS), request forgery, and various injection attacks
- They are often managed cloud services or managed security service provider (MSSP)/cloud access security broker (CASB) solutions from different vendors
- **The AWS WAF can be deployed on an elastic application load balancer, content delivery network (CDN) distribution, or application programming interface (API) gateway**

Cloud-based WAF Solution

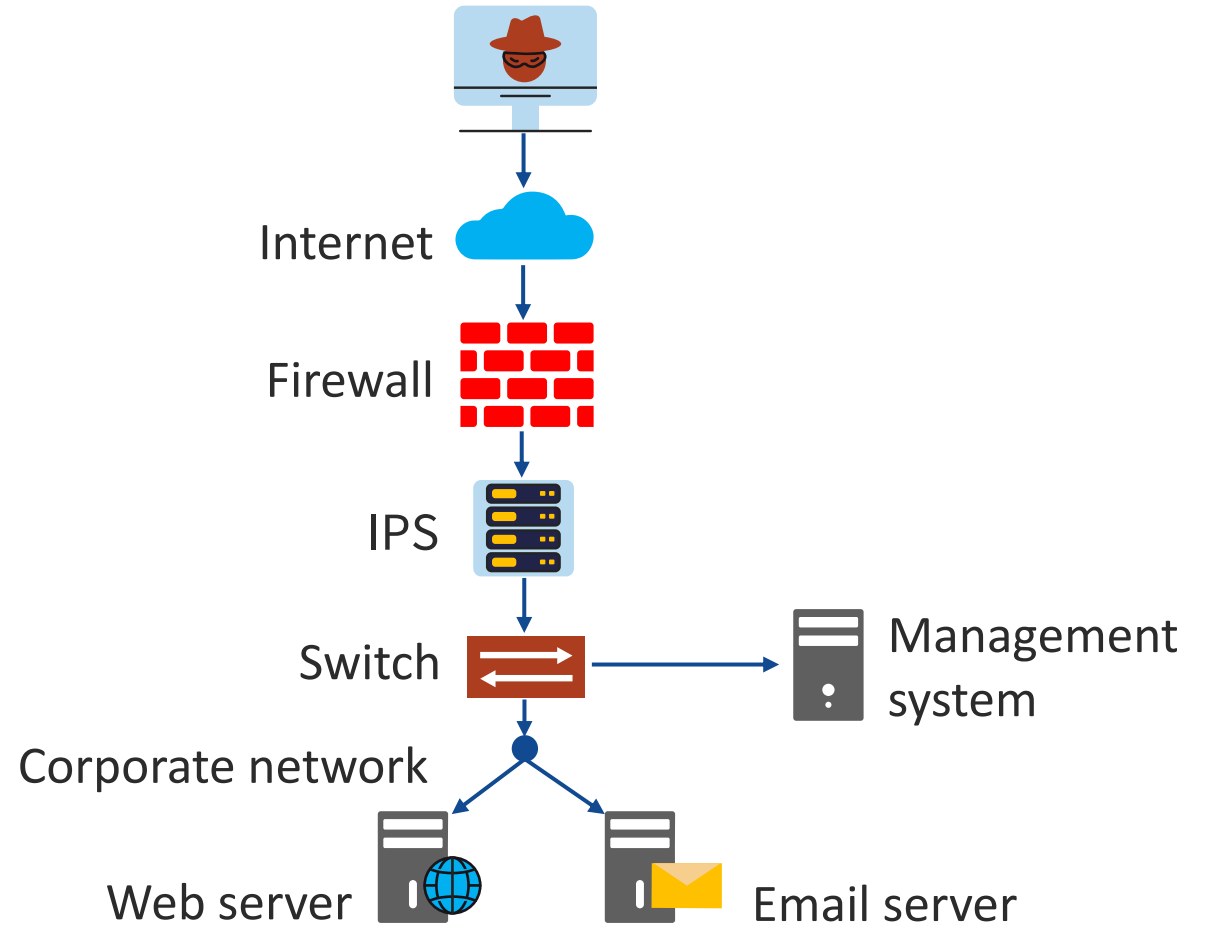


TRADITIONAL IDS VS. IPS

Intrusion detection system (IDS)

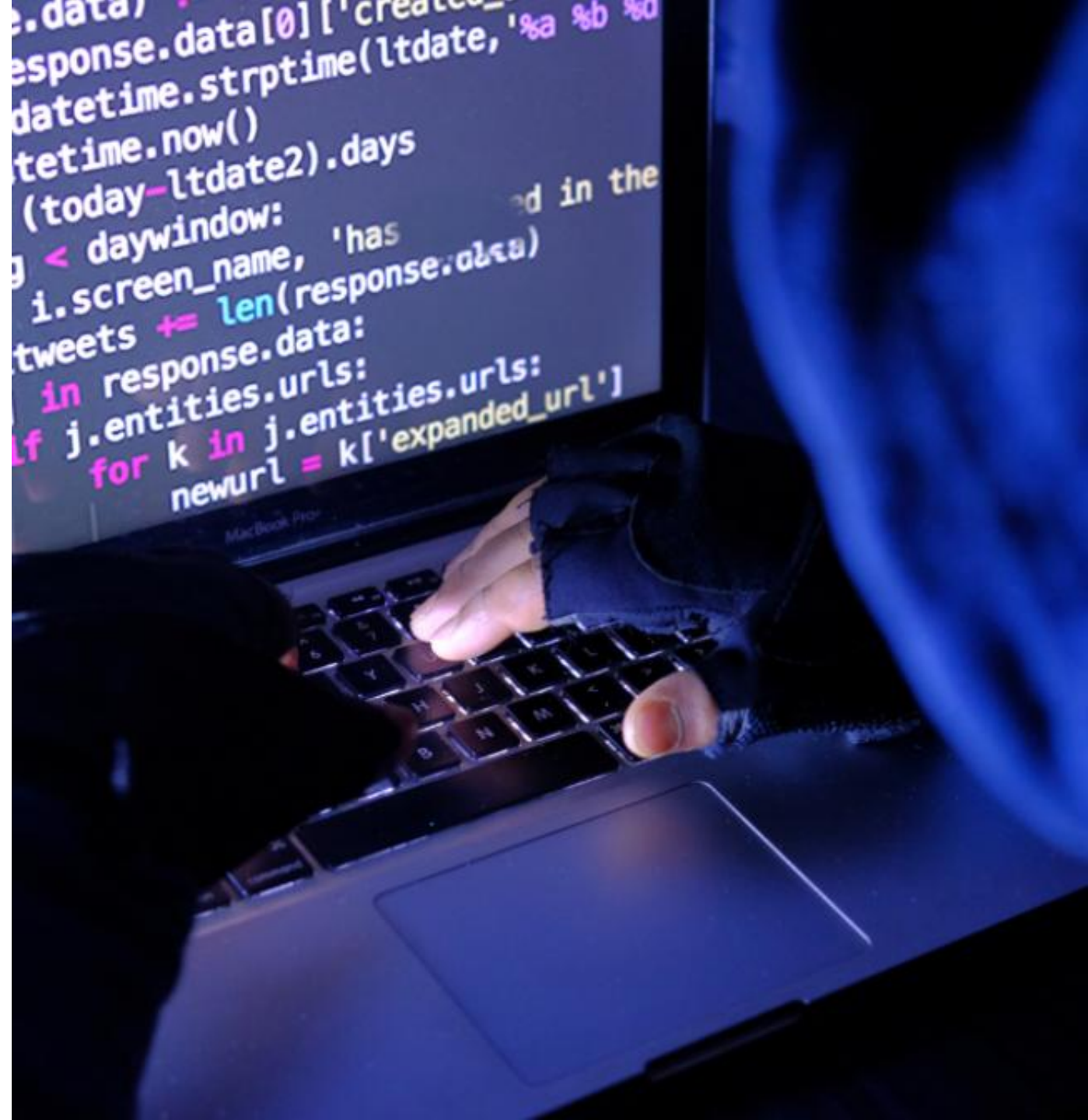


Intrusion prevention system (IPS)



Next Generation IPS (NGIPS)

- IPS solutions have evolved rapidly over the last ten years
- NGIPS is a security implementation technology that delivers intelligence and visibility to protect the infrastructure from cyber attacks and related threats
- NGIPS is commonly integrated into unified threat management appliances and next generation firewalls



NGIPS

- Another trend for NGIPS is to connect with cloud-based providers and Software as a Service (SaaS) and CASB network services
- NGIPS forwards and transports Internet Protocol (IP) packets to all information and services
- NGIPS also has built-in sandboxing and advanced malware protection components





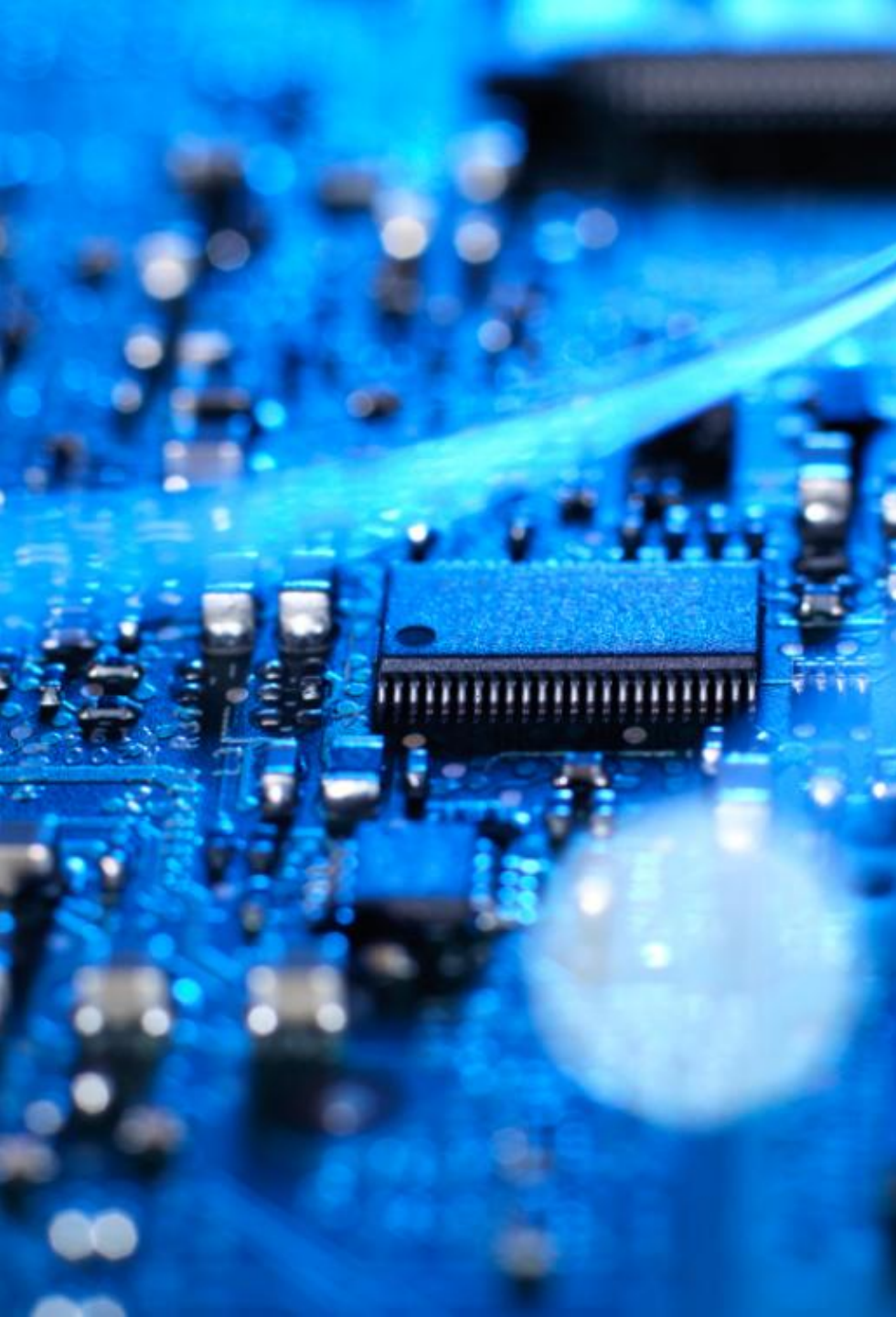
NGIPS Features

- **Visibility:**

- NGIPS allows security managers to see more contextual data from your network and fine-tune your security
- NGIPS can see all applications, indicators of compromise, file disposition
- It also offers sandboxing, vulnerability data, and device-level OS views

- **Effectiveness:**

- Secure IPS solutions typically get new policy rules and signatures every couple of hours, so that security is up to date
- Solutions leverage global threat detection networks to bring security effectiveness to the products



NGIPS Features

- **Cost optimization:**
 - Automation enhances operational productivity and lowers overhead by separating actionable events from noise
- **Flexibility and agility:**
 - NGIPS has flexible deployment options
 - It can be deployed at the corporate edge, in the data center distribution/core, or behind the firewall
 - Secure IPS can be deployed for inline prevention or passive detection
- **Integration:**
 - NGIPS integrates into modern networks without major hardware modifications or substantial downtime
 - They have a single unified portal with a single pane in the security operations center



Managed Security Service Providers (MSSPs)

- A common next-generation IPS solution comes from MSSPs offering outsourced security monitoring and management for security systems and devices
- Common MSSP services are
 - IDS/IPS
 - Managed layer 3-7 firewalls
 - Endpoint response and detection
 - Virtual private networking support
 - Vulnerability scanning and antiviral services

Blacklisting (Blocklist)



- Blacklisting operates on a permissive model: all traffic or applications are allowed by default unless explicitly denied
- This method relies heavily on known threat signatures or malicious IPs, domains, or behaviors that are cataloged and blocked
- While blacklisting is easier to implement and less restrictive, it is inherently reactive—only effective against threats that have already been identified
- This leaves systems vulnerable to zero-day exploits or novel attack vectors that haven't yet made it onto the blacklist
- In IDPS, blacklisting is often tied to signature-based detection, where known patterns trigger alerts or blocks

Whitelisting (Allowlist)



- Whitelisting, on the other hand, embodies a “default deny” posture, aligning more closely with zero-trust principles emphasized in modern cybersecurity frameworks
- Only pre-approved applications, IPs, or behaviors are permitted, and everything else is blocked by default
- This proactive stance significantly reduces the attack surface, especially in environments where system integrity and operational consistency are critical
- In firewalls, whitelisting enforces strict traffic rules, often requiring granular configuration and ongoing maintenance to avoid disrupting legitimate operations
- Within IDPS, whitelisting can be behavior-based, allowing only known-good patterns and flagging anomalies



Sandboxing

- Sandboxing is a practice where professionals run code or applications in an insulated environment such as a type 1 or type 2 hypervisor
- This detonation chamber is used to test code or applications that may potentially be dangerous
- Sandboxing environments are often for threat modeling and reverse-engineering of malware
- Sandboxing is designed to reduce threats from entering the network by analyzing and eliminating them

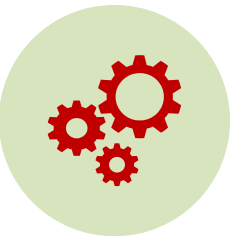
Types of Sandboxing



Manual sandboxing requires human interaction to operate - although this offers a high level of control, setup and use can be time-consuming



Automatic sandboxing is designed to function with minimal human intervention for quicker and more scalable analyses



Hybrid sandboxing blends both manual and automatic approaches, balancing control with efficiency so users can adapt their sandboxing techniques





Sandbox Environment Features

- **Virtual machines** running in on-site and CSP private cloud deployments are leveraged to simulate entire computer systems
- **Emulators** imitate certain hardware or software components, allowing for granular testing
- **System-level sandboxes** are fully isolated systems for observing possibly malicious code that affects system-level processes
- **Application-level sandboxes** confine an application's access to specific system resources to test potentially malicious code while stopping any widespread damage

Sandboxing Analysis Types

- **Static analysis** looks at questionable code without executing it:
 - This exposes known malicious patterns without placing the code in a runtime state
- **Dynamic/runtime analysis** examines the code in real-time as it runs within the sandbox environment:
 - This helps to discover the malicious actions that only happen during execution
- **Memory dump analysis** comprises inspecting the memory image from the sandbox to detect malicious code running in volatile memory:
 - This practice is critical for exposing newer threats that reside only in memory and with few other trace behaviors

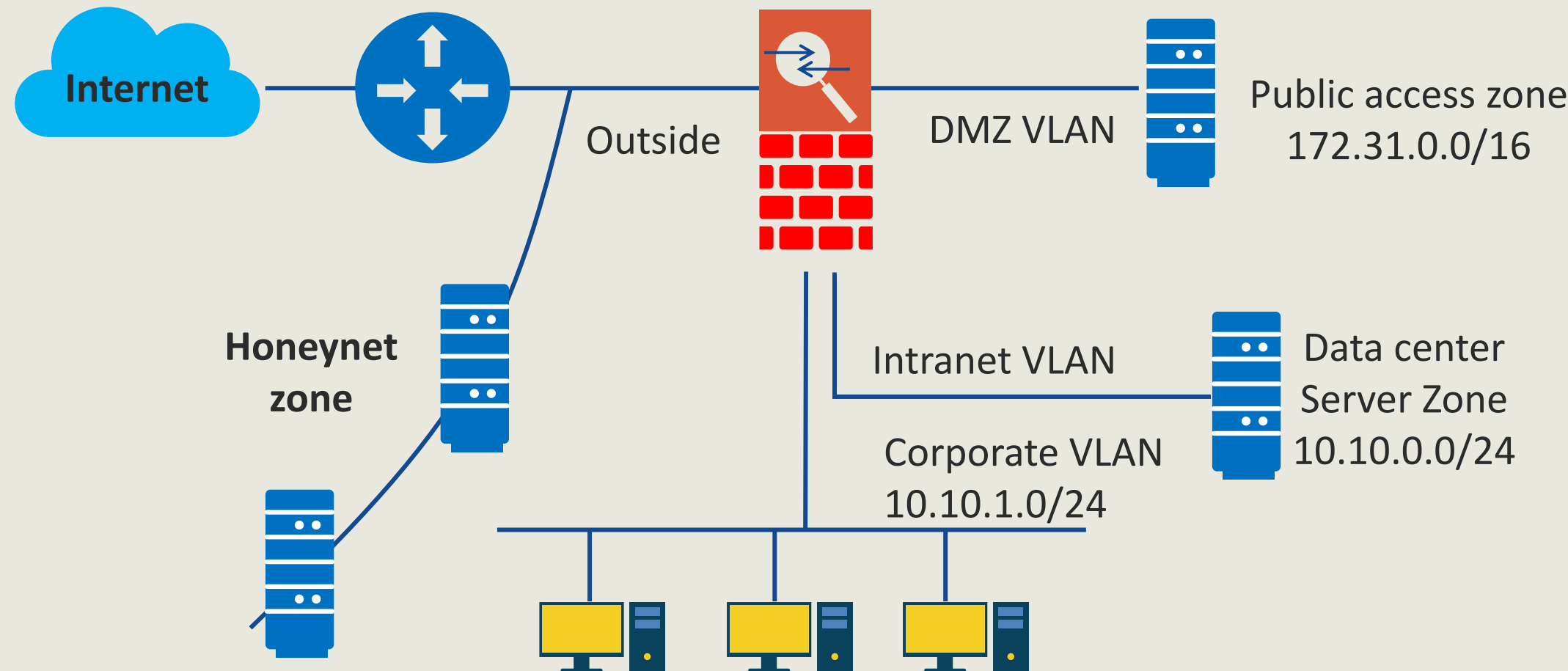


Honeypots and Honeynets

- Honeypots and honeynets are isolated systems, sites, and services with data that appear to be legitimate and valuable to an advanced persistent threat actor
- They entice potential malicious users to connect (internal or external)
- IDS and security information and event management (SIEM) systems track and log all traffic to and from the honeypot
- Blue teams will perform active defense procedures
- Security orchestration, automation, and response (SOAR) runbooks can also be run for counterattack/active defense initiatives



Honeynet Zones





Active Defense: Deception

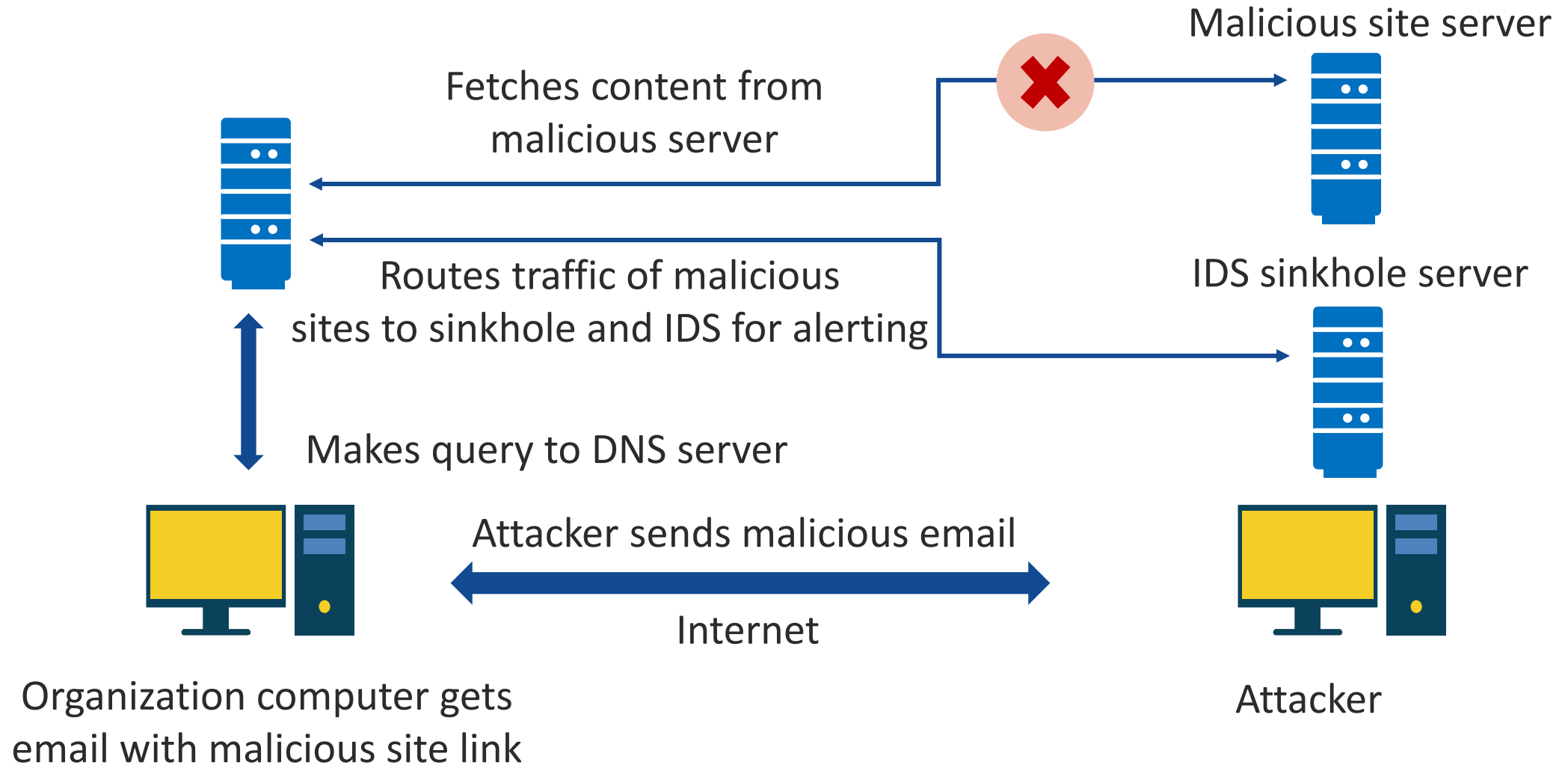
- Deception is the first and most common phase of active defense used by many organizations
- Fake telemetry involves augmenting existing enterprise tools to offer critical threat intelligence for early breach detection and high-fidelity alerting
- It involves making tools available on honeypots and honeynets for attackers to use to attribute and attack back

DNS Sinkholes

- DNS sinkhole (or black hole DNS) is used to spoof DNS servers to prevent resolving hostnames of specified URLs
- This can be accomplished by configuring the DNS forwarder to return a false IP address to a specific URL
- It can be used against attackers to slow them down in a honeynet deployment and then possibly perform active defense attribution techniques
- Can also be used to prevent access to malicious URLs at an enterprise level for internal users

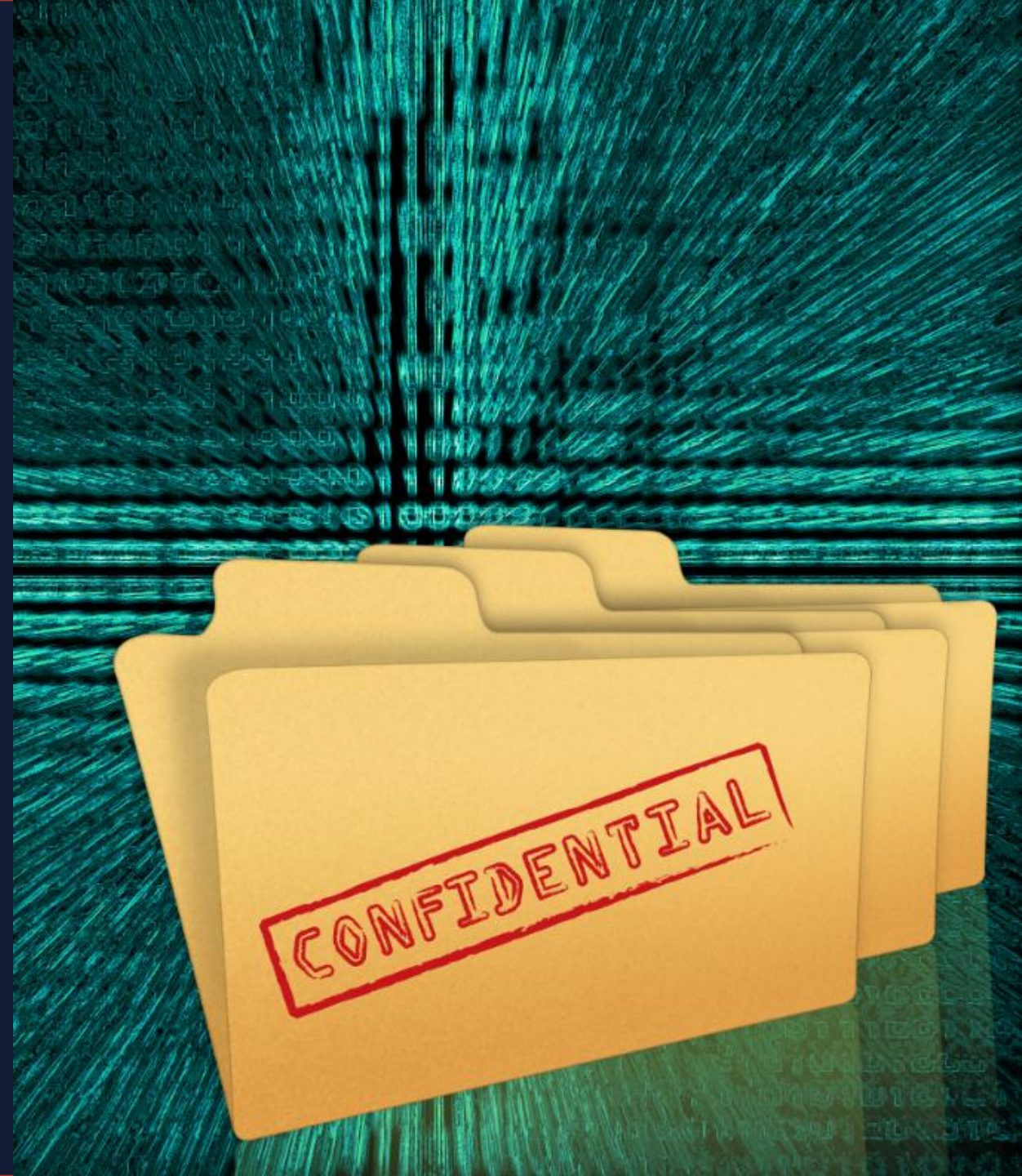


DNS Sinkhole



Honeytokens

- Honeytokens are a piece of fake or deliberately misleading data used to locate and expose compromised privileged insiders
- These are artifacts placed in strategic locations to be discovered and used by suspects in an unauthorized manner
- Common examples are:
 - Fake privileged accounts to a database system or directory service
 - Access keys to dummy cloud provider accounts
 - Additional balances added to petty cash or discretionary expense funds



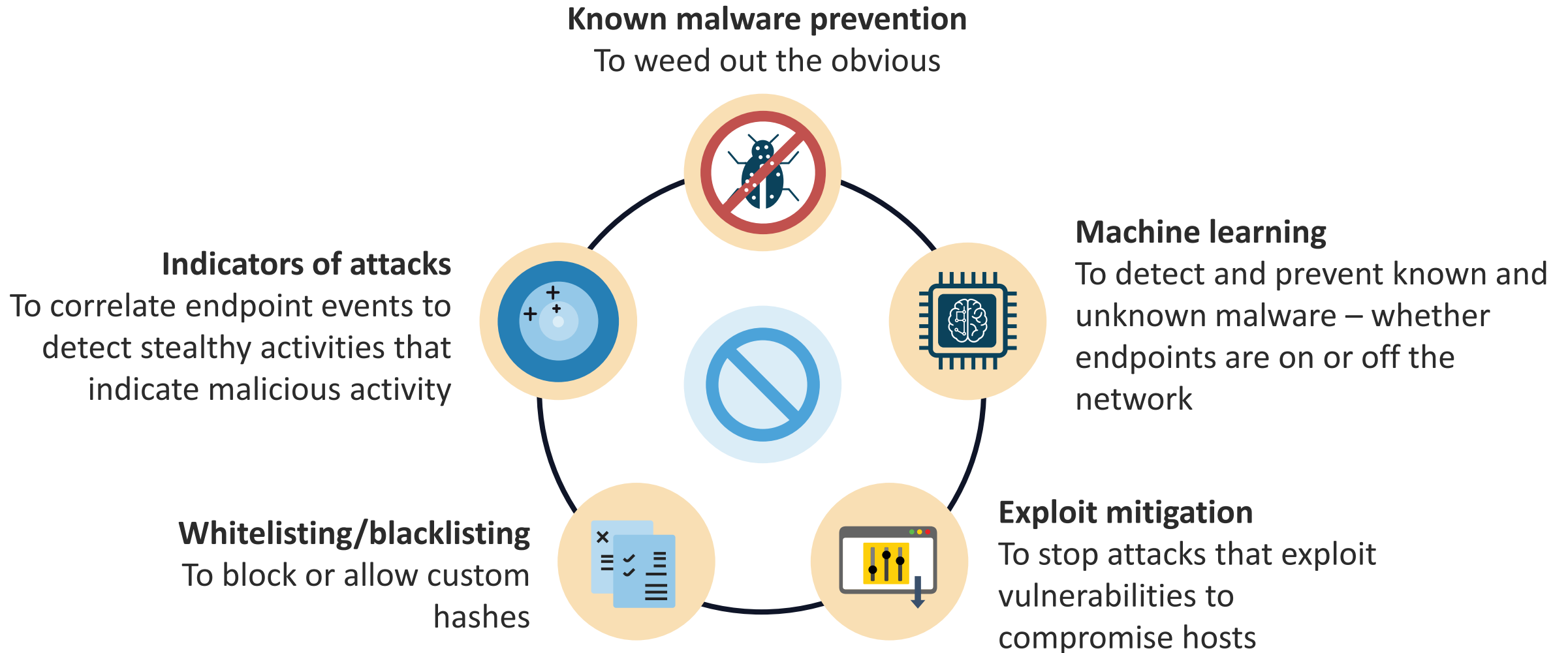


Antimalware

- Antimalware refers to software or systems designed to detect, prevent, and remove malicious software—including viruses, worms, trojans, ransomware, spyware, and other forms of malware
- It is intended to proactively and dynamically protect applications and information systems as well as individual endpoints
- Antimalware programs will persistently scan a system to thwart, detect, quarantine, and eradicate potentially unwanted programs (PUPs) and code

Next-Generation Anti-Virus

- NGAV uses a suite of AI, behavioral recognition, ML engines, and attack mitigation to anticipate and prevent known and unknown threats
- NGAV is typically cloud or vendor-based
- It can be deployed in hours and offload the overhead of maintaining software, managing infrastructure, and updating signature databases to a third-party



ML and AI-based Tools

- ML security tools can identify patterns and forecast threats in huge data sets at machine speed
- By automating the analysis, blue security teams can quickly discover active parts of the kill chain, incursion artifacts, and indicators of compromise
- ML tools then isolate scenarios in hypervisors or the cloud that need further human analysis





ML and AI-based Tools

- Machine learning detects threats by continually monitoring the activities of the network for anomalies
- ML engines process huge volumes of data in near real-time to expose critical incidents and vulnerabilities
- ML and AI techniques enable advanced visibility into insider threats, unknown malware, and policy violations
- Cloud services like AWS GuardDuty use ML and AI to perform pre-crime activities against domains and IP prefixes 7-10 days in advance of the release of zero days

Business Continuity Planning and Exercises

Objectives

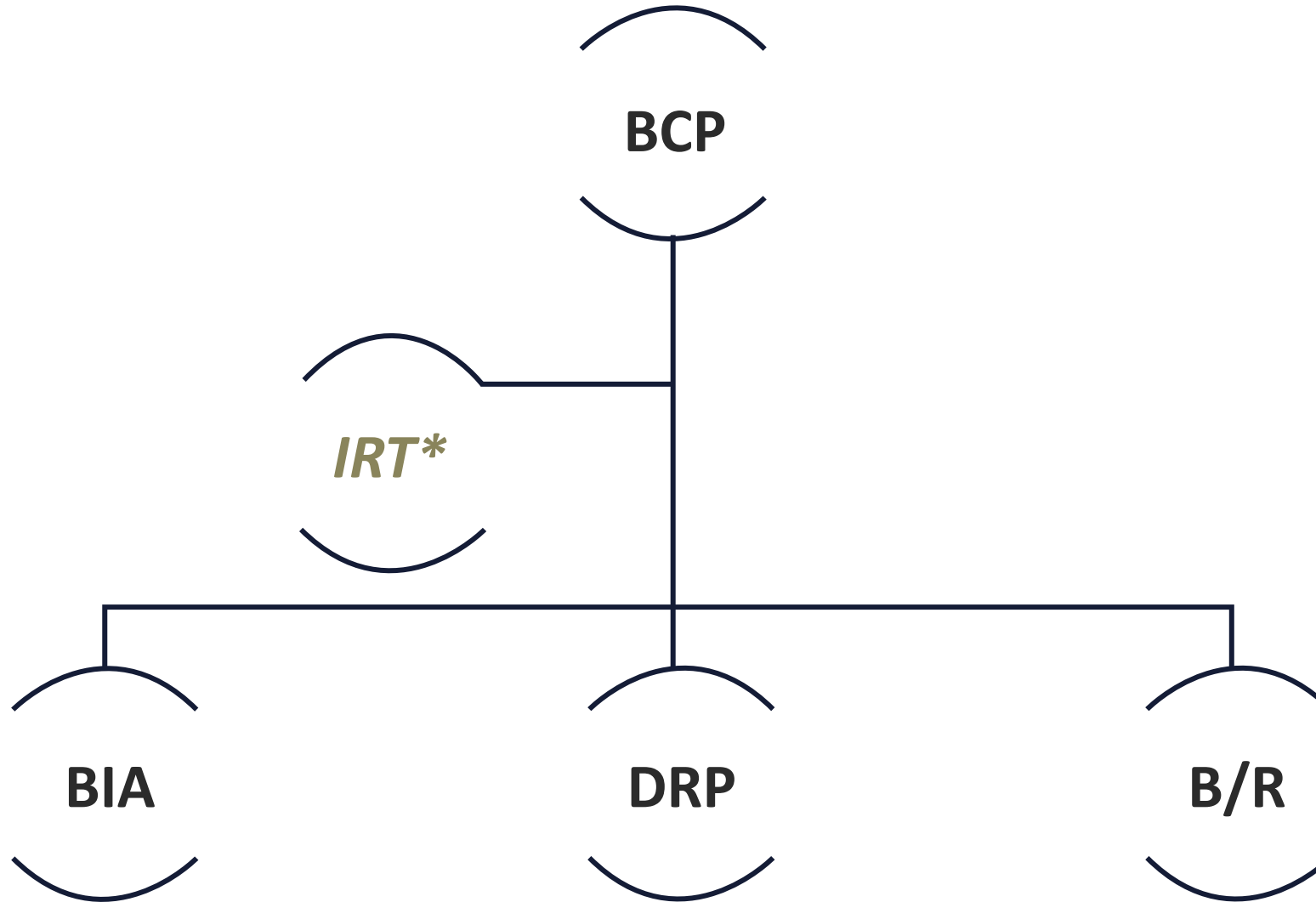
- Describe business continuity requirements and business impact analysis (BIA)
- Explore backup storage and recovery site strategies
- Compare multiple processing sites
- Examine system resilience, high availability, quality of service, and fault tolerance
- Explain business continuity planning and exercises



Business Continuity Planning (BCP)

- For government agencies and other non-commercial entities, the term continuity of operations planning (COOP) is often used instead
- BCP involves the development and preparation of all activities and procedures deployed to avert the loss of critical business functions and services for a pre-determined acceptable amount of time
- It is often driven by an initial gap analysis that is an aspect of corporate security strategy and governance
- **The first step is to define the scope of the BCP**

Business Continuity Planning





BCP – NIST SP 800-34, Rev 1

1. Develop a continuity planning policy statement
2. Conduct the business impact analysis
3. Identify preventive controls
4. Create contingency strategies
5. Develop an information system contingency plan
6. Ensure plan testing, training, and exercises
7. After-action report
8. Ensure plan maintenance

Threats to Continuity

Environmental

- Earthquakes
- Wildfires
- Flooding
- Snow
- Tsunamis
- Hurricanes
- Tornadoes
- Landslides
- Asteroids

Man-made intentional

- Arson
- Terrorist
- Political
- Break-ins
- Theft
- Damage
- File destruction
- Information disclosure

Man-made unintentional

- Configuration errors and mistakes
- Power outage
- Illness
- Epidemics
- Information disclosure
- Damage
- File destruction
- Coding errors

BCP from ready.gov (U.S. DHS)

Business impact analysis

- Develop questionnaire
- Conduct workshop to instruct business function and process managers how to complete BIA
- Receive complete BIA questionnaire forms
- Review BIA questionnaires
- Conduct follow-up interviews to validate information and fill any gaps

Recovery strategies

- Identify and document resource requirements based on BIAs
- Conduct gap analysis to determine gaps between recovery requirements and current capabilities
- Explore recovery strategy options
- Select recovery strategies with management approval
- Implement strategies

Plan development

- Develop plan framework
- Organize recovery teams
- Develop relocation plans
- Write business continuity and IT disaster recovery procedure
- Document manual workarounds
- Assemble plan
- Validate and gain management approval

Testing and exercises

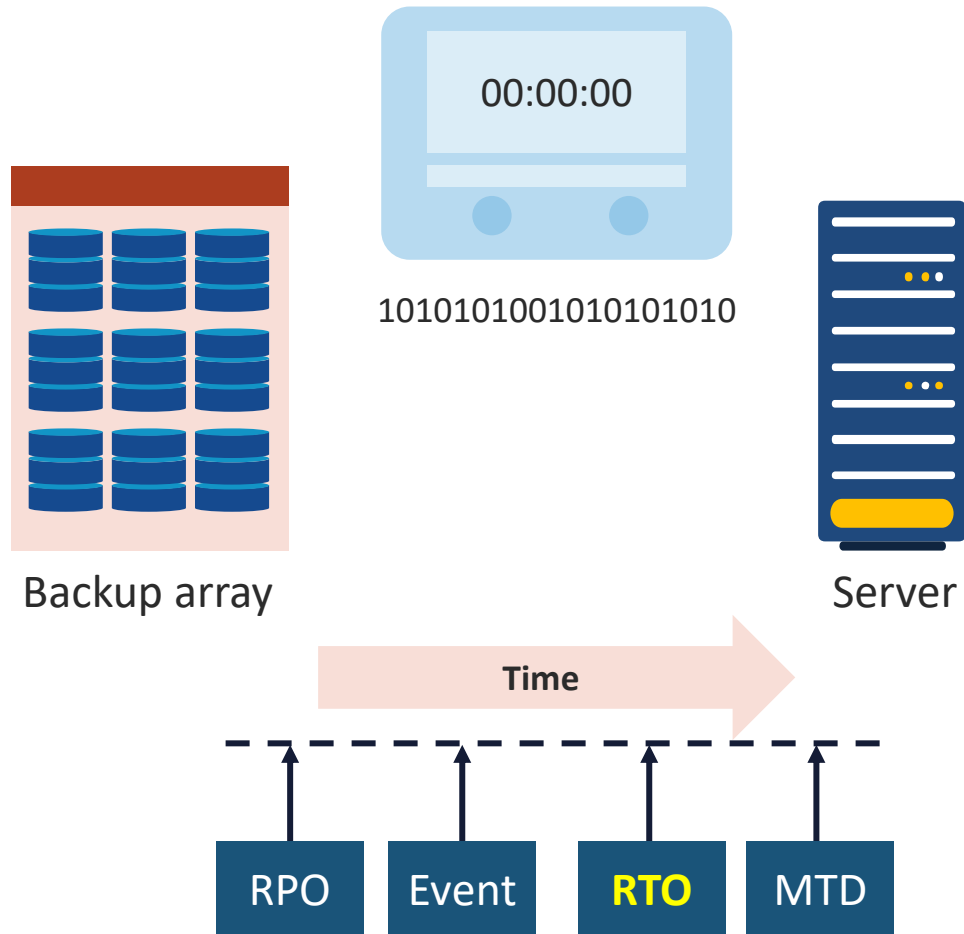
- Develop testing, exercise, and maintenance requirements
- Conduct training for business continuity team
- Conduct orientation exercises
- Conduct testing and document test results
- Update BCP to incorporate lessons learned from testing and exercises

Business Impact Analysis

- The BIA is the quantitative risk assessment aspect of the BCP
- The primary goal is to identify critical functions to the business and prioritize them based on need for survival and continuity
- Groups must gather meaningful metrics and indicators and categorize the risks associated with the critical functions
 - The probability of the risk occurring (likelihood)
 - The impact the risk will have (magnitude)
 - Identify how to eliminate or reduce the risk

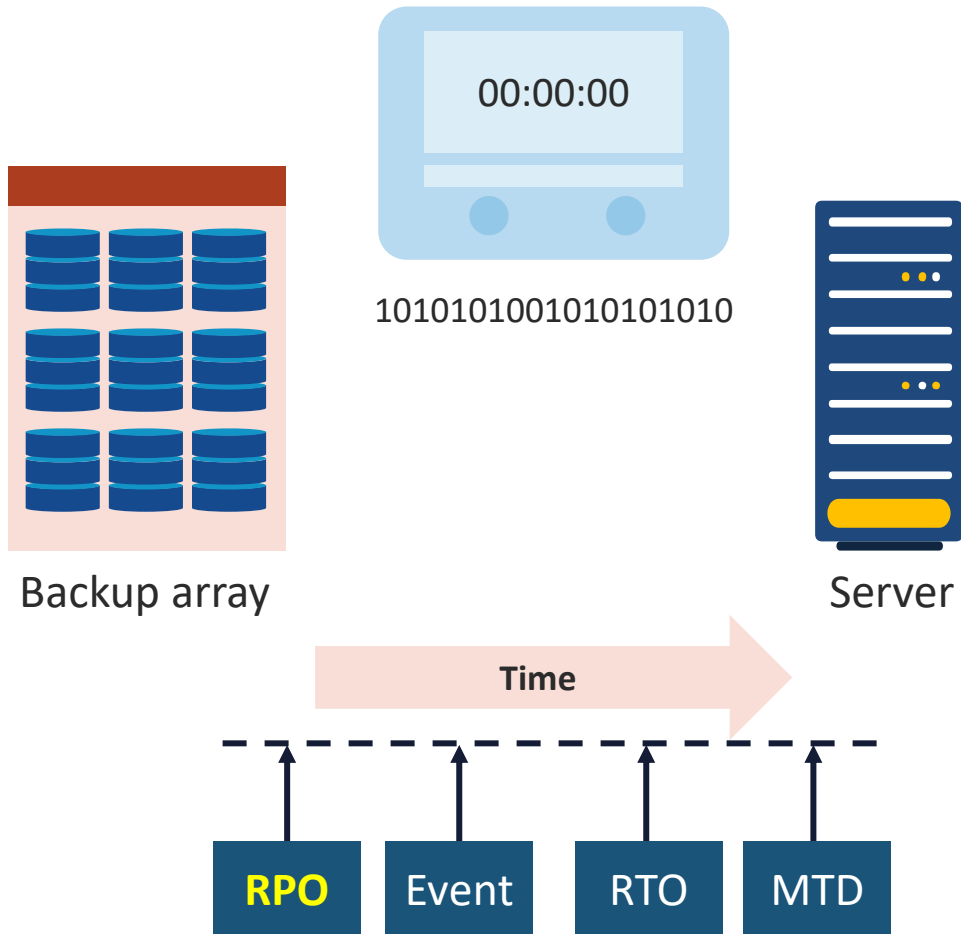


Recovery Time Objective (RTO)



- The amount of time available to recover the resource, service, and function
 - IT must be equal to or less than MTD
- Any BIA solutions must be accomplished within this time frame, or it is considered loss
- Ways to lower the impact of disasters include:
 - Hardening physical security
 - Adding redundancy
 - Purchasing insurance
 - Investing in bigger generators
 - Utilizing faster and more robust supply chains
 - Safeguarding media off-site or in the cloud

Recovery Point Objective (RPO)



- The point in time, relative to a disaster, where the recovery process begins
- In IT systems, it is often the point in time when the last successful backup or transaction log was done before the disruptive event occurs
- Also including:
 - Last Known Good configuration
 - Image or instance snapshot
 - Recovery volume update
 - State Machine
 - Transaction logs

Mean Time between Failure

- MTBF is a measure of the dependability of a component or system
 - The average time that it will operate before it fails
- MTBF is a maintenance metric, represented in hours usually gathered from the OEM or reliable reviewer
 - It is calculated as the arithmetic mean time between failures of a system
 - For example, a solid-state drive (SSD) drive may have a mean time between failures of 10 years
- MTBF is also used to evaluate performance, safety, and component design





Mean Time to Replace (or Repair)

- MTTR considerations
 - How is this metric affected by supply chain disruptions?
 - How long does it take to repair, fix, or replace a system, device, or component?
- It is the average value predicted based on experience and documentation
- $MTTR = (\text{Total down time}) / (\text{number of breakdowns})$

BIA External Dependencies

- Supply chain
- Vendors and manufacturers
- Warehousers
- Distributors
- Large customers
- Strategic partners (B2B)
- Service-level (master) agreement
- Reciprocal agreement
- Regulators





Full Backups

- The process backs up everything regardless of whether the archive bit is set or not
 - Clears the archive bit once the backup completes
- This method takes the longest to back up and the time depends on how much must be backed up
- A full backup is quickest to restore as only the most recent full backup is required
- A full backup should be scheduled, automated, and tested although it is common to perform this manually

Incremental Backups

- This method backs up any new file or any file that has changed since
 - The last full backup
 - The last incremental backup
- Subsequent backups only store changes that were made since the previous backup
- An incremental backup clears the archive bit once the backup completes
- The process of restoring lost data from an incremental backup is longer, but the backup process is much quicker
- It is not recommended to perform incremental backups manually



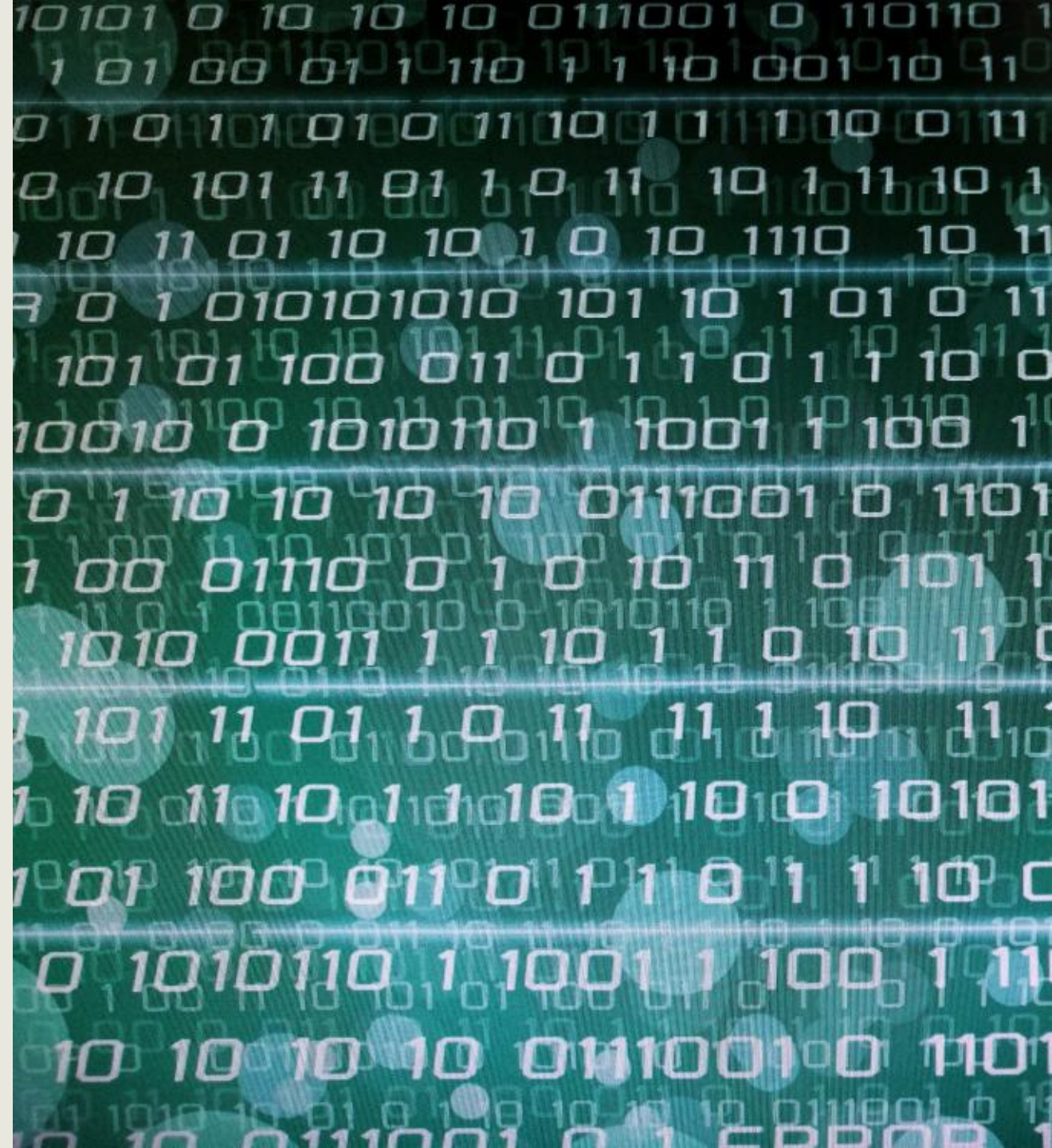


Differential Backups

- This method backs up any file that has the archive bit set
- Backs up any new file or any file that has changed since the last full backup
- A differential back up DOES NOT clear the archive bit when the backup completes
- It is slow to back up but quick to restore
- The last full backup and the most recent differential backup are needed for restoration
- It is not recommended to perform differential backups manually

Snapshots

- Immediate point-in-time virtual copies of the source data
- Offers easier and faster backups and restores
- Should be replicated to another medium or cloud storage to be considered a backup
- Time to back up does not increase with amount of data
- Improved RTO and RPO - restores are fast
- Less data is lost with an outage
- Can easily be encrypted and decrypted
- **Snapshots are NOT a replacement for a comprehensive backup plan**



Backup Frequency

- Backup frequency is often based on the business impact analysis metric known as RPO
 - RPO is the maximum amount of data loss that you can tolerate in case of a disaster
 - The lower the RPO, the more frequently you need to back up your data
- The type of database management system (DBMS), data volume, data change rate, and performance needs all contribute to deciding the best backup strategy





Backup Frequency

- Commonly, full backups are conducted automatically or manually at least once a week, or more frequently depending on the criticality or latency of the data
- Differential backups should be done daily if the RPO is low or the data changes regularly
- Incremental backups should be done hourly if the RPO is very low or the data changes very rapidly
- Snapshots are common techniques for virtual data and should also be automated and scheduled based on various recovery points and time objectives

Onsite vs. Offsite Backup Strategies

Accessibility

Offsite backup is not as reliable to access physically as the data is stored in different geographical locations



Cost

For entities with a lot of data, cloud-based backup solutions can be quite cost-efficient in the long run using Infrastructure as a Service (IaaS) and Platform as a Service (PaaS)



Security

Onsite may be as secure as offsite if a large resource commitment is made for administrative, physical, and technical security controls

Onsite vs. Offsite Backup Strategies

Scalability

Scalability is one of the huge advantages of offsite data backup where the cloud service provider (CSP) is responsible for providing the storage



Support and maintenance

With on-premises solutions, the organization has the most control with their own support team responsible for data backup

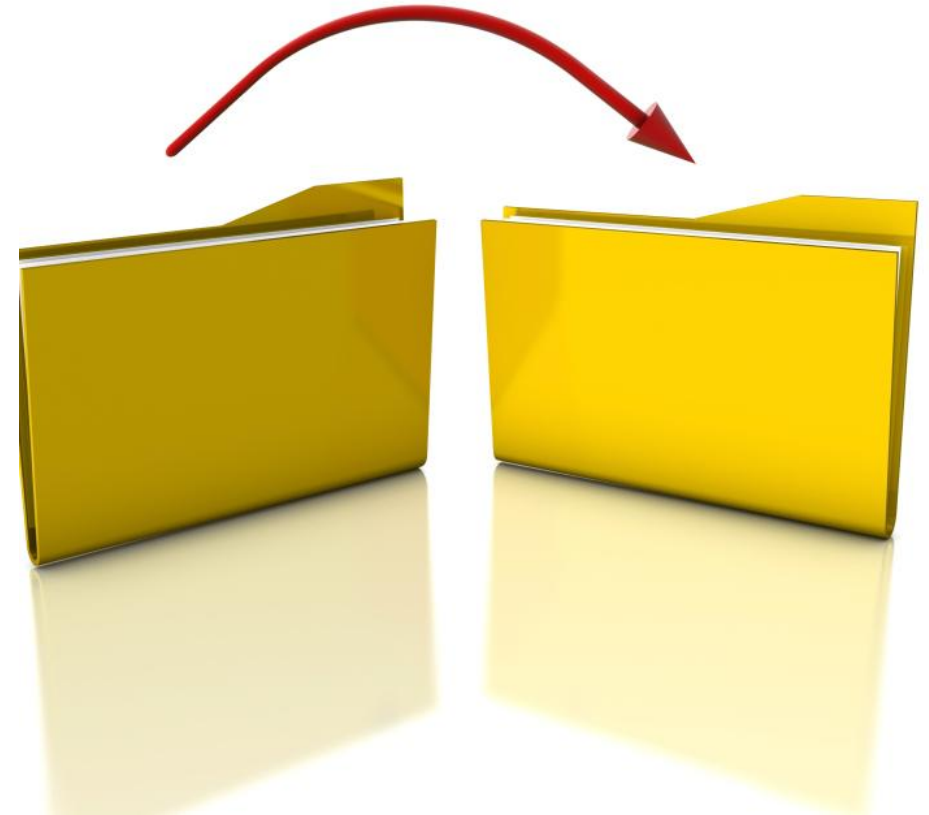


Reliability

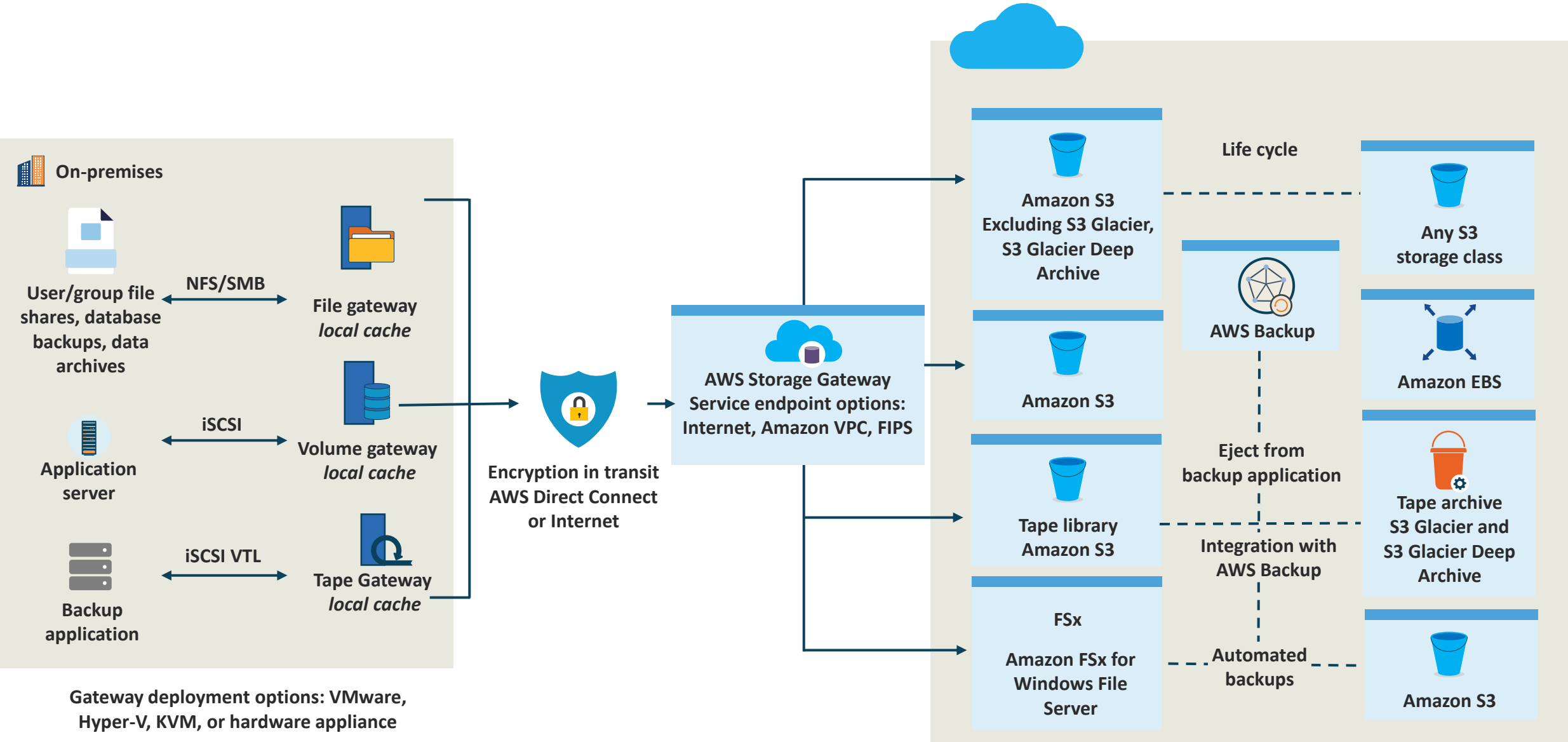
Offsite data backup is more reliable because the data is not stored in the same place as the original data

Verifying Data Backup

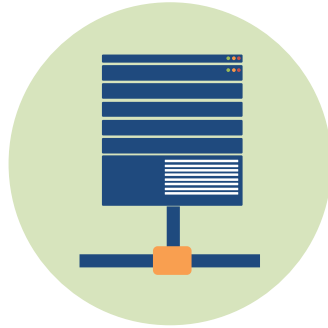
- The primary incident response control for ransomware is a tested and verified data backup process
- This verification procedure is also a critical aspect to overall disaster recovery planning
- Modern hybrid cloud solutions with on-site physical or virtual storage gateways are enhancing the backup policies and processes
- **Hypervisor storage (pods or datastore) clusters are key modern targets**



Example: AWS Storage Gateway



Backup Verification Best Practices



Intermittently verify all manual backups



Examine backup data analytically



Test backups in various cases (misuse or abuse case)

Backup Verification Best Practices



Focus on mission-critical data first



Confirm available space and budget for backups



Understand availability vs. durability service-level agreements (SLAs)

Recovery and Restoration

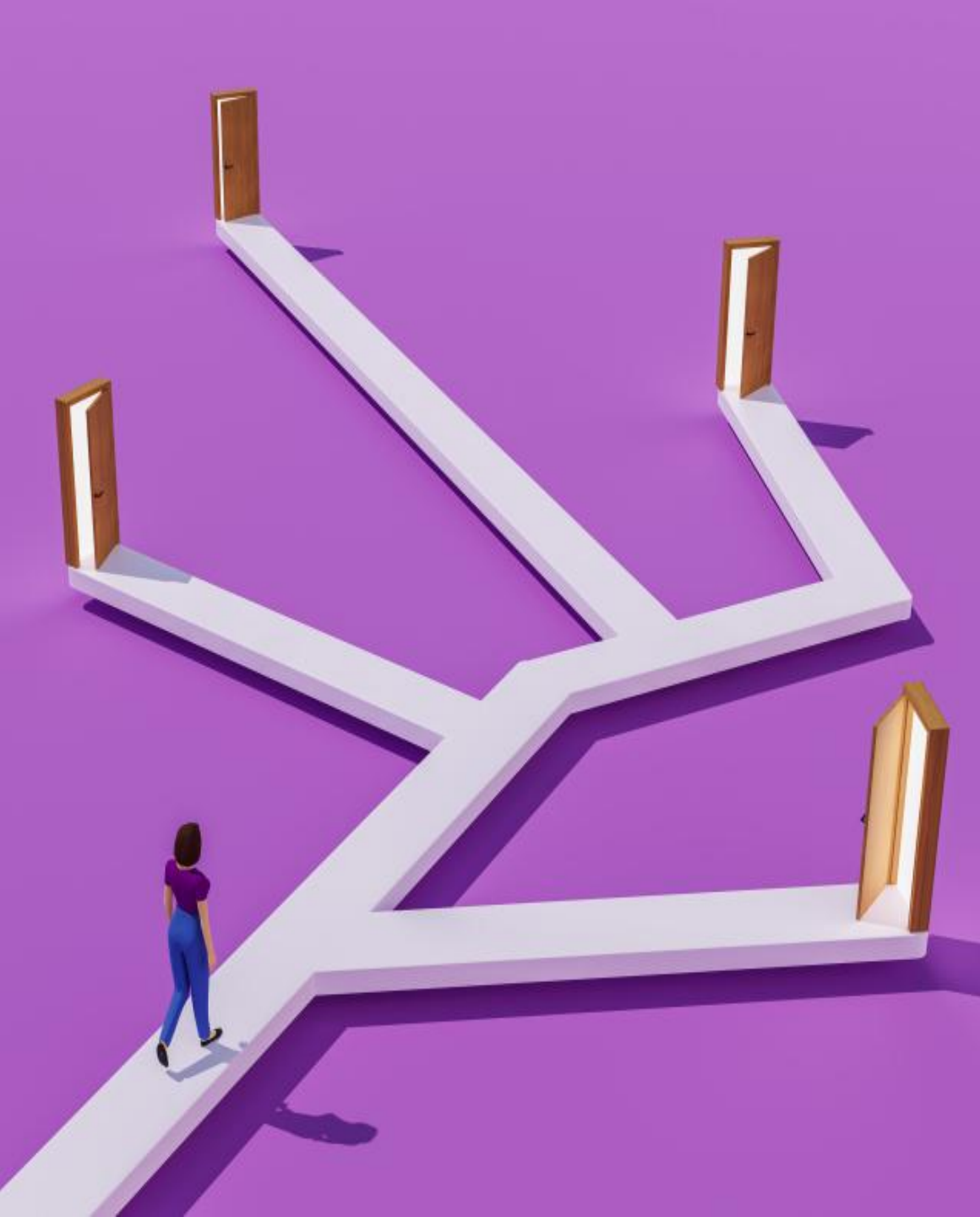
- Without a comprehensive well-tested recovery and restoration practice there is no real backup strategy
- Many organizations have relied on regular automated backups when suffering a ransomware attack only to find out there were configuration errors or gaps that were not discovered through ongoing recovery testing
- The team that performs recovery is often different than the backup operators due to Separation of Duties (SOD)





Multipath Connectivity

- Uninterrupted service and constant access are critical to the daily operation and productivity of the enterprise
- Since downtime leads directly to loss of income, datacenters must be designed for redundant, fail-safe reliability and availability
- Datacenter reliability is also defined by the performance of the infrastructure



Multipath Connectivity

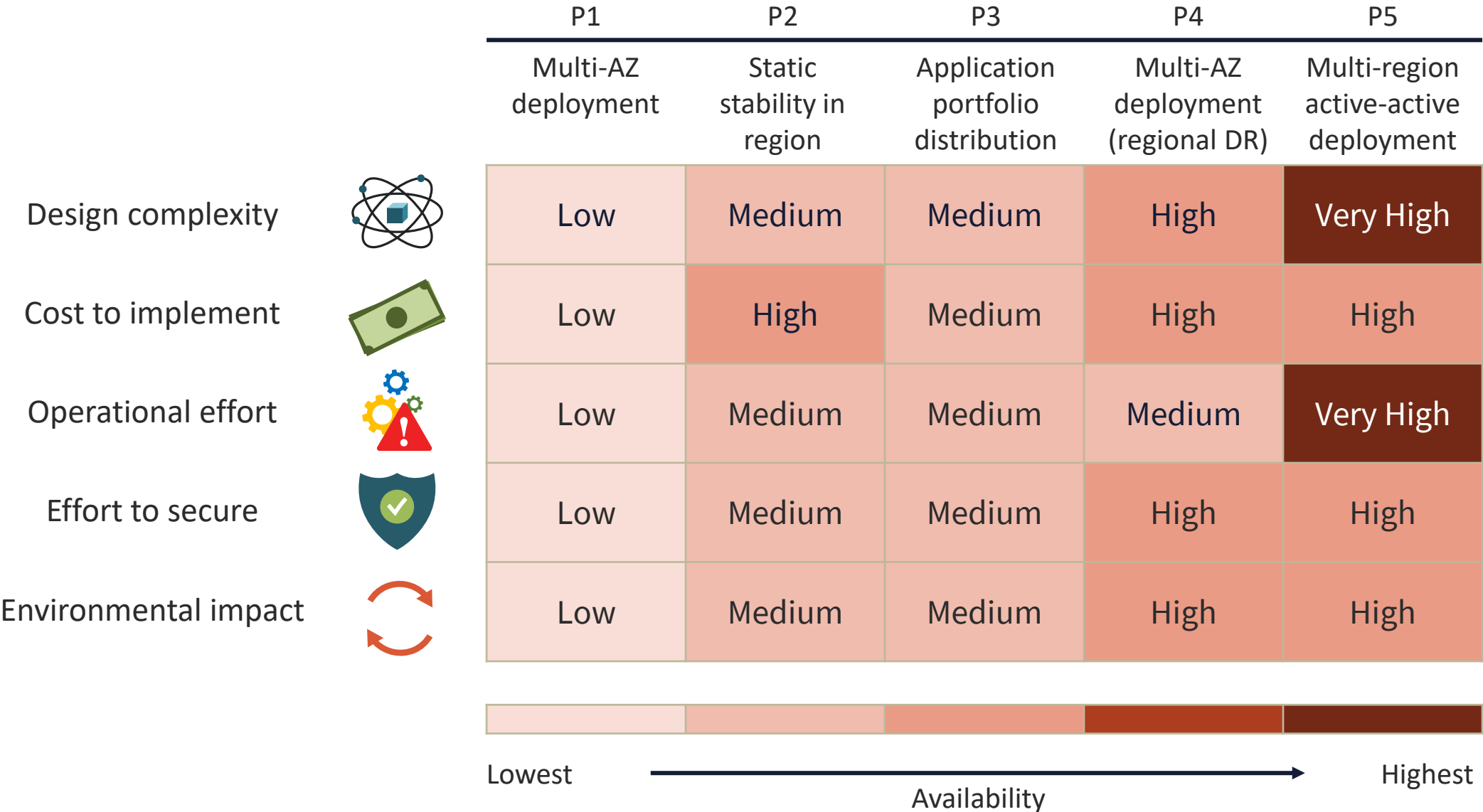
- Cabling and connectivity backed by a trustworthy vendor service-level agreement (SLA) with guaranteed error-free performance will help avoid poor data transmission in the datacenter
- There should be redundant connectivity from multiple providers into the datacenter
 - This will help prevent a single point of failure for network connectivity
- The redundant paths should deliver the minimum expected connection speeds (**10/100/400Gb**) for datacenter operations

Resilience

- Enterprise resilience relates to an organization's ability to anticipate and respond to change, survive catastrophic events, and to learn from the experiences
- Resilience is the capacity for weathering systemic interruptions and adjusting to the introduction of emerging risks and vulnerabilities
- It practically refers to an organization's ability to withstand, adapt, and mature in the face of unexpected changes



Design Resilient



Redundancy

- **Passive** redundancy uses additional capacity to reduce the impact of component failures
 - Active/passive failover
 - Hot spares
 - Snapshots
- **Active** redundancy eliminates performance problems by having simultaneous capacity in use
 - Active/active failover
 - Hot, mirrored, or parallel sites



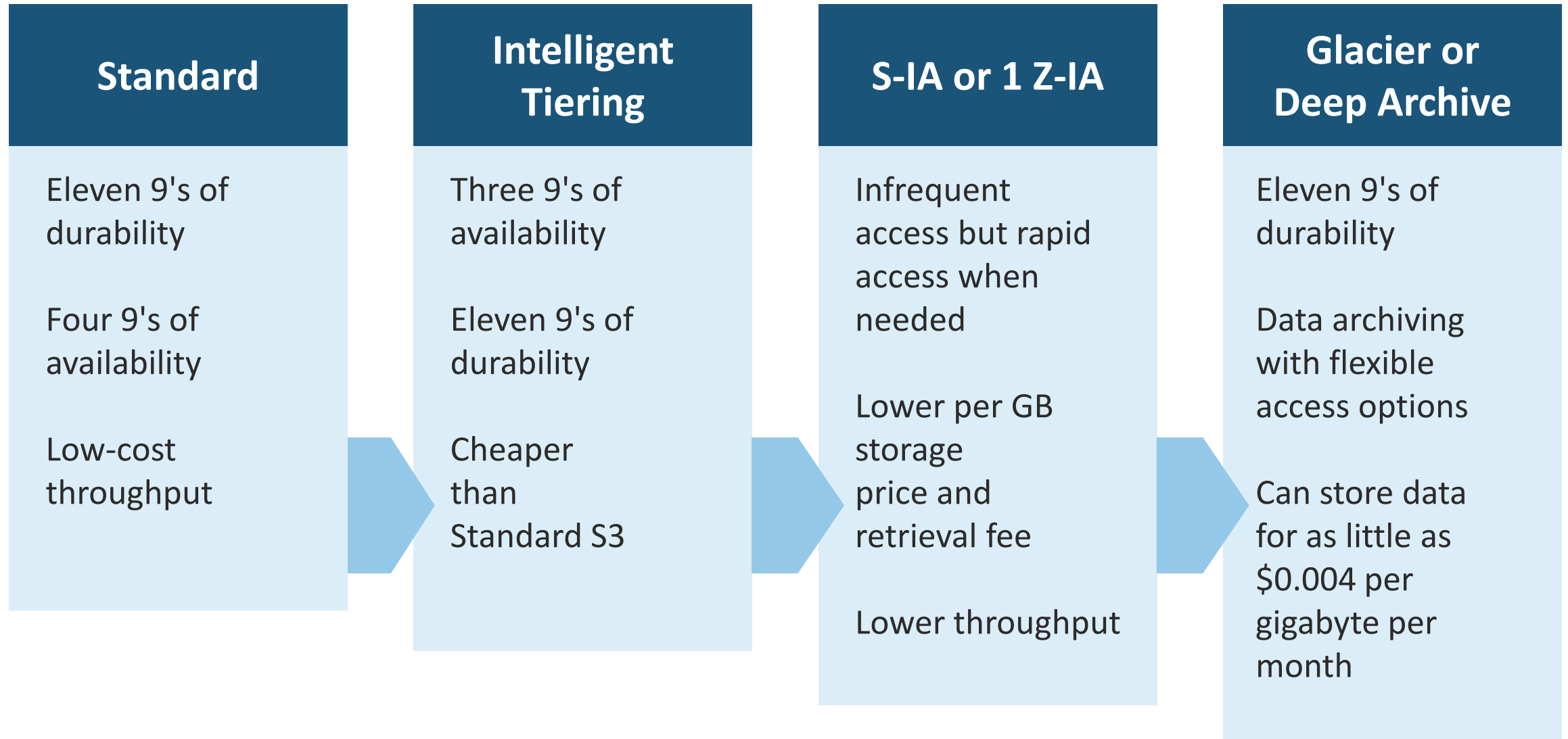
Availability vs. Durability

- **Availability** refers to system uptime (i.e., the storage system is operational and can deliver data upon request)
- Historically, this has been achieved through hardware redundancy so that if any component fails, access to data or services remain



- **Durability**, on the other hand, refers to long-term data protection
- The stored data does not suffer from bit rot, degradation, or other corruption
- Rather than focusing on hardware redundancy, it is concerned with data redundancy so that data is never lost or compromised

CSP Storage Plans (AWS)



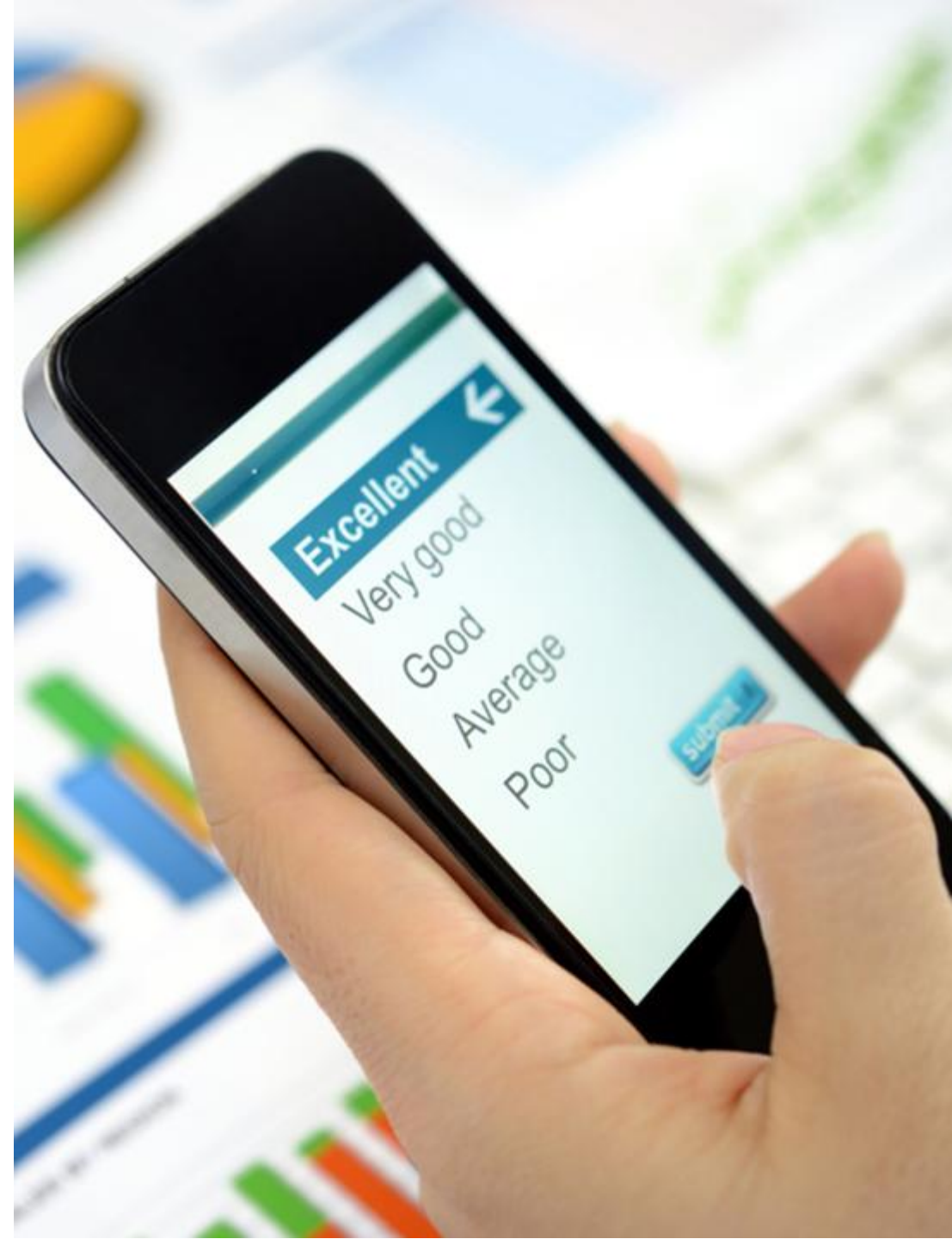


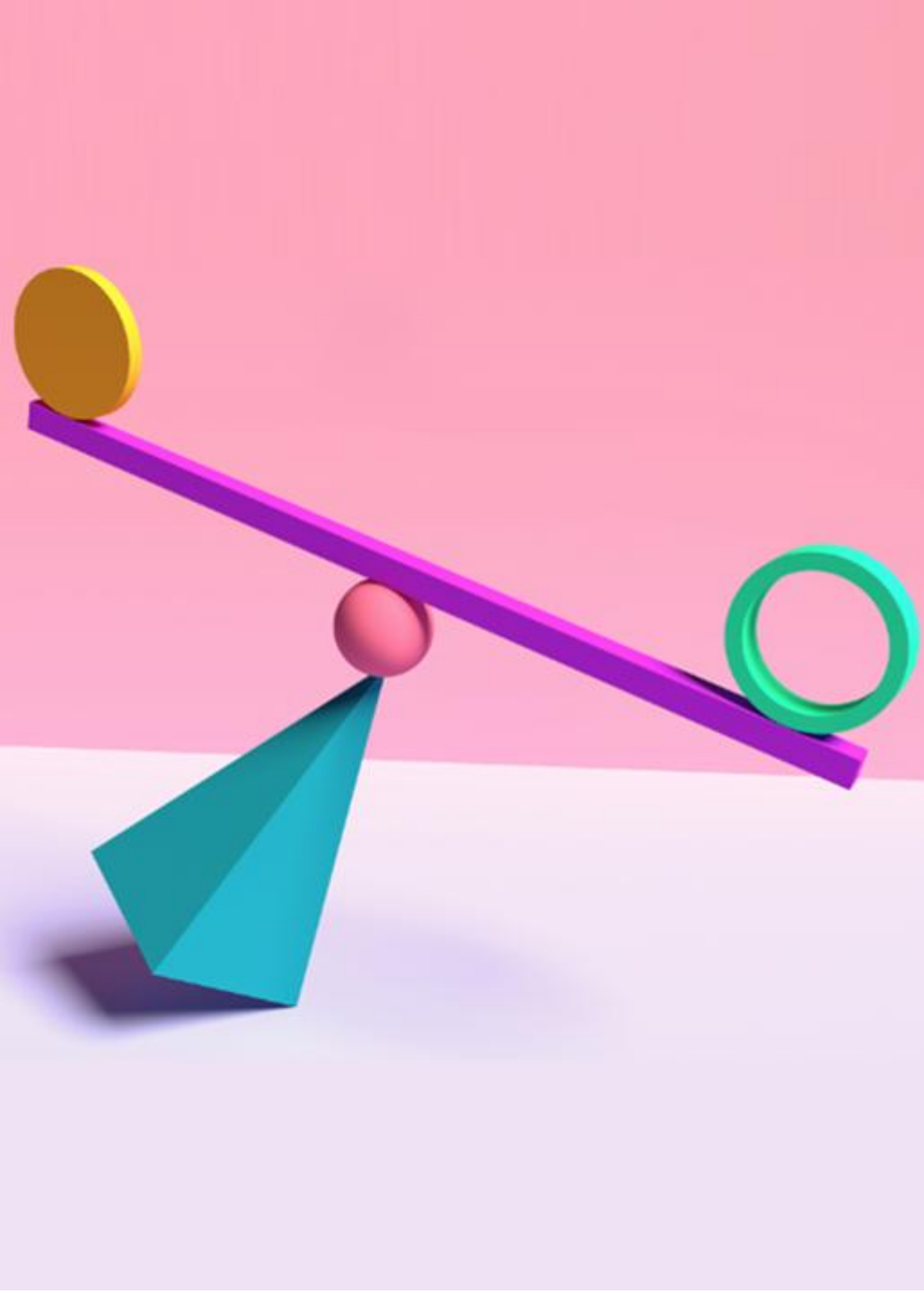
Quality of Service (QoS)

- QoS is commonly a metric used to evaluate the reliability of the delivery of frames, cells, and packets over wired and wireless networks
- The steady and high-quality service availability is a critical concern of network administrators for critical applications and protocols
- As applications, apps, and devices demand more bandwidth, QoS is a vital tool to assure a predictable level of availability (CIA)

Quality of Service

- One of the main objectives in preserving QoS is making sure that critical or time-sensitive applications receive priority over other traffic
- For example, voice over IP (VoIP), conferencing, and streaming packets should get higher priority than normal data transfers
- Users should not experience dropped packets, latency, or delays
- **QoS isn't just about bandwidth – it is about prioritization, reliability, and control**



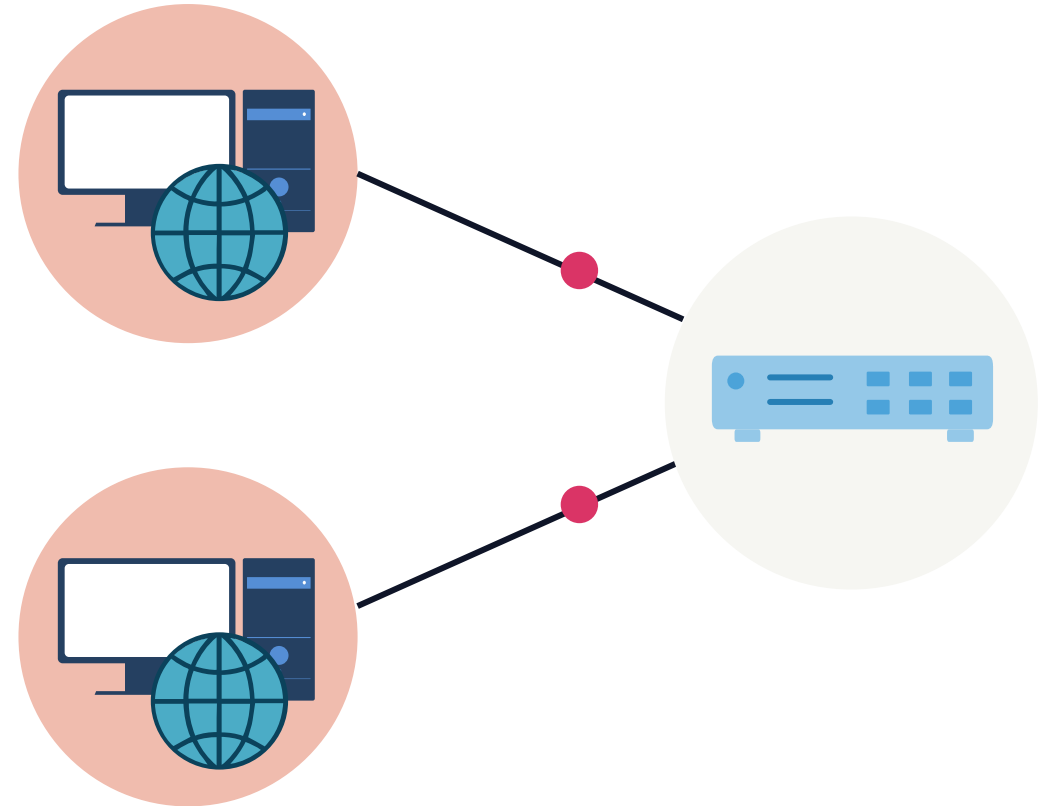


Load Balancing

- Load balancing devices and services are popular due to the usage of data and network intensive applications and services
- They can optimize application availability and performance
- They distribute Transmission Control Protocol (TCP), User Datagram Protocol (UDP), Hypertext Transfer Protocol (HTTP), and Transport Layer Security (TLS) traffic across multiple servers to efficiently allocate resources and offer failover solutions

Load Balancing

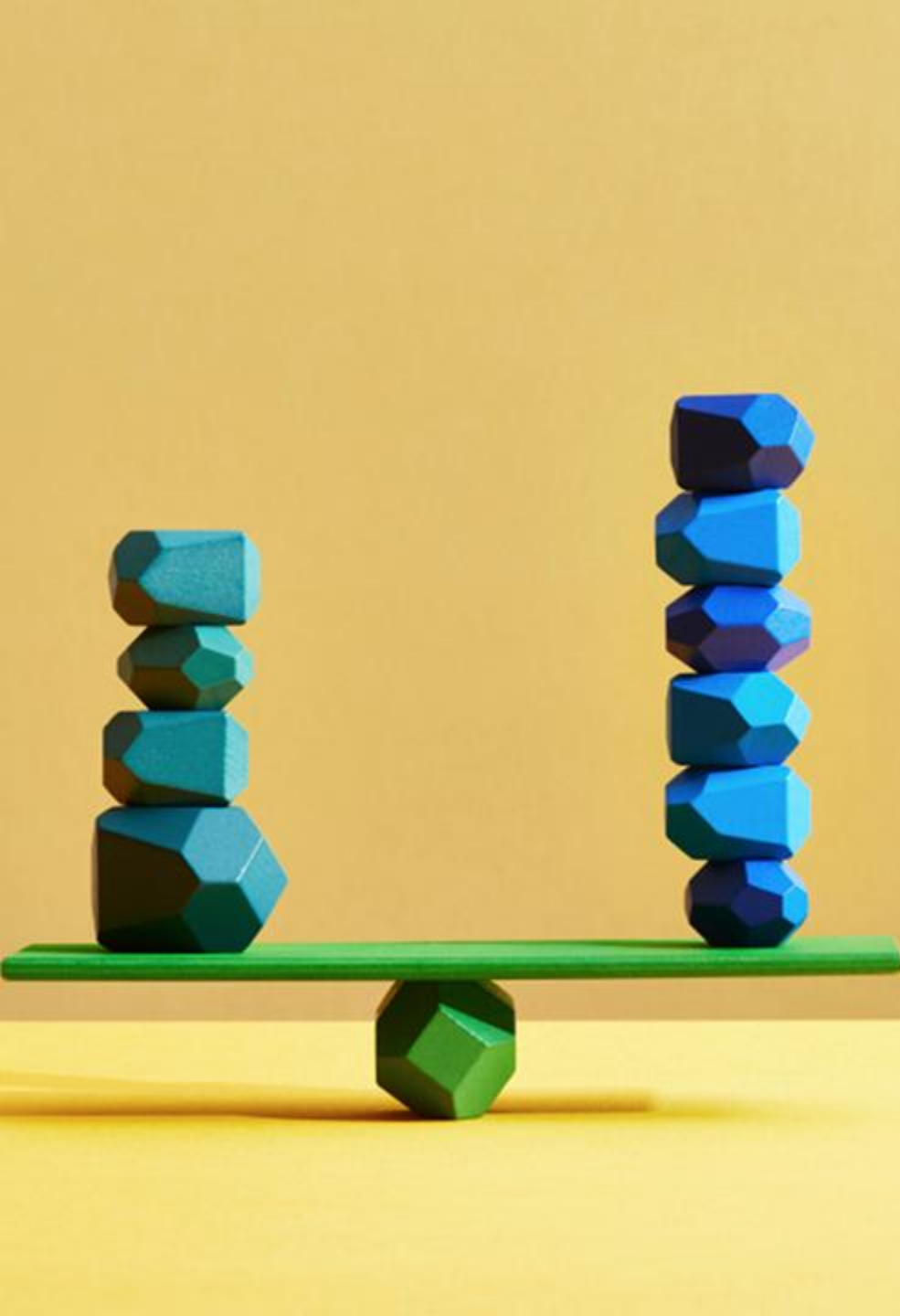
- Dedicated load balancing appliances and modules have become a standard component in physical and virtual networks
- All the major network equipment vendors offer load balancing solutions to basically "put traffic in its place"
- These systems can optimize application availability and performance, distribute traffic across multiple servers, and offer failover solutions



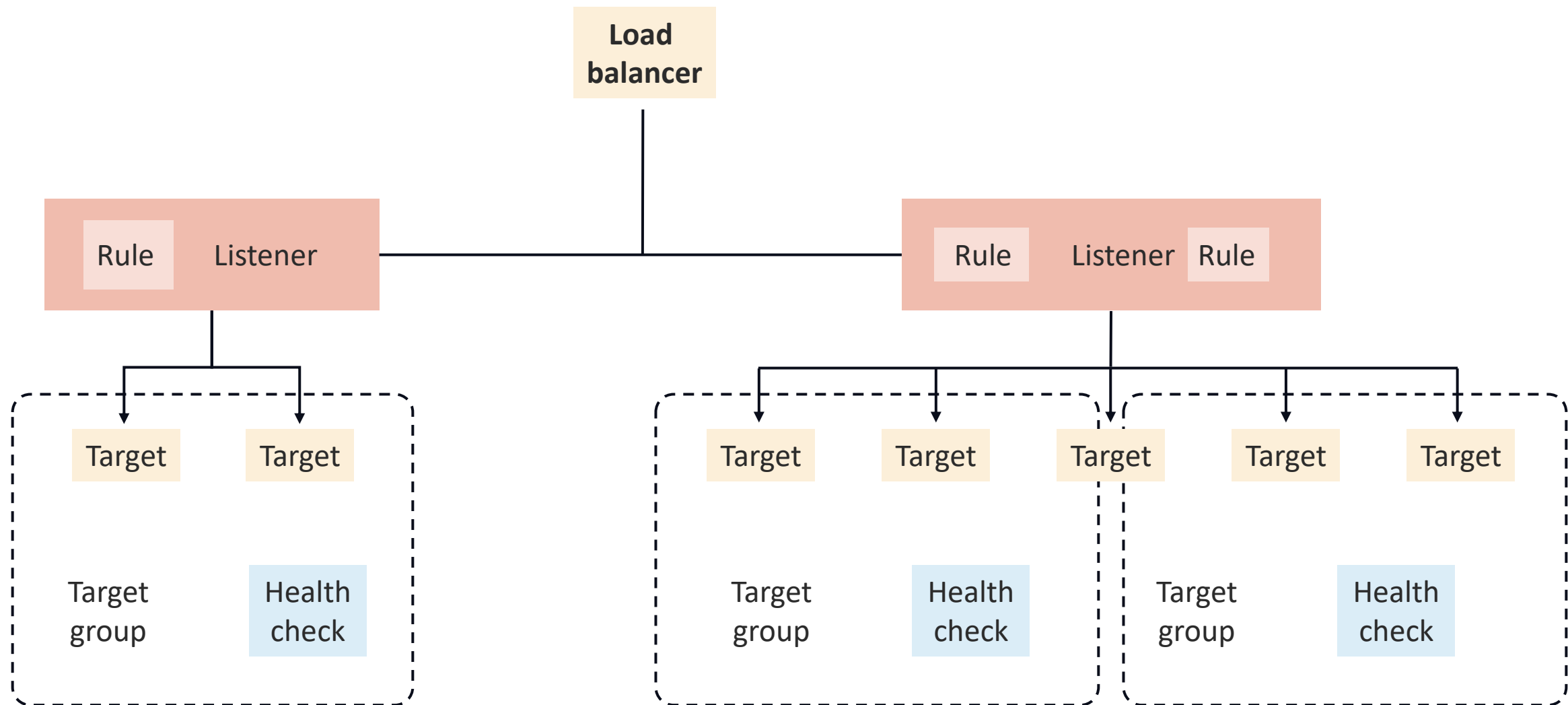
Load balancer

Load Balancing at Cloud Providers

- The 3 main types of cloud load balancers are **application, network and gateway**
- They often represent virtual network to the public based on IP address or public domain name
- LBs perform health checks on back-end instances and containers
- They produce flow logs for other threat management services
- LBs run a certificate service or TLS listener to decrypt traffic for the web application firewalls



Cloud Load Balancers



Clustering

- Clustering refers to the process of grouping similar data points or objects together based on shared characteristics, often used in security analytics to detect patterns, anomalies, or threats within large datasets
- Clusters can be designed to be a redundant set of service functionalities based on active-standby or active-active deployments
- **A primary target of modern load balancers is a cluster**
- Clustering is intended to improve performance and availability of a complex physical or virtual system





Clustering

- Cluster deployments are often measured by:
 - **Reliability** – the ability to successfully provide responses on each incoming request
 - **Availability** – the uptime of the server (usually measured as % of annual uptime)
 - **Performance** – measured by the average of the time spent by the service to provide responses or by the throughput
 - **Scalability** – the ability to handle a growing amount of work in a capable manner without degradation in the quality of service



Clustering and Load Balancing

- Both load balancing and server clustering technologies are often used together to coordinate multiple servers to handle a larger workload
- Server clusters typically require identical hardware and versioning to function optimally
- Load balancers can be used to distribute workload to different types of servers and can be more easily integrated into existing architecture
- Both technologies often integrate reverse-proxy techniques that allow for a single IP address to redirect traffic to different IP or MAC addresses

Clustering Techniques

- **High-performance clusters** use multiple servers to execute a specific task very quickly and support data-intensive projects such as live-streaming and real-time data processing
- **Storage clusters** offer massive storage arrays, sometimes in support of high-performance clusters, but always in a support role for other servers or clusters such as storage area networking or hypervisor cluster data stores



RAID Comparisons

Features	RAID 0	RAID 1	RAID 5	RAID 6	RAID 10
Minimum number of drives	2	2	3	4	4
Fault tolerance	None	Single-drive failure	Single-drive failure	Two-drive failure	Up to one disk failure in each sub-array
Read performance	High	Medium	Low	Low	High
Write performance	High	Medium	Low	Low	Medium
Capacity utilization	100%	50%	67-94%	50-88%	50%

IMPLEMENT DISASTER RECOVERY

Objectives

- Provide an overview of disaster recovery (DR) response and personnel in the disaster recovery plan (DRP)
- Compare communications methods
- Describe DRP assessment and restoration
- Outline disaster recovery plan tests, lessons learned, and communicating test results
- Describe training and awareness for disaster recovery planning



DISASTER RECOVERY PLANNING

- DR planning involves ensuring that managers can help the organization recover **to an acceptable level** from any type of catastrophic event
- A cataclysmic event is relative to the organization as it can be a single drive ransomware attack to an entire facility or campus being put out of action
- The DRP should contain detailed steps for recovering from any kind of data loss or physical disaster

ELEMENTS OF DISASTER RECOVERY PLANS

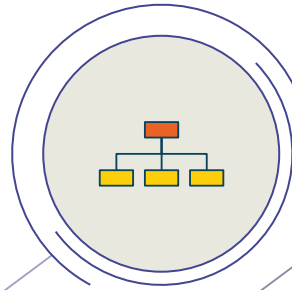
- Order of succession and command
- Step-by-step instructions on how to recover each aspect of critical systems, applications, and data
- Backup and restore plans with order of restoration
- Contact information for law enforcement, legal, insurance, media outlets, and more
- Location of hot spares, software and CD keys, security access keys and failsafe passwords, and other valuable documentation
- DRP site locations and descriptions
- **These plans and information should also be physical hard copies**



PERSONNEL IN THE DR PROCESS

Organizational charts

Have physical and digital copies of the roles and responsibilities



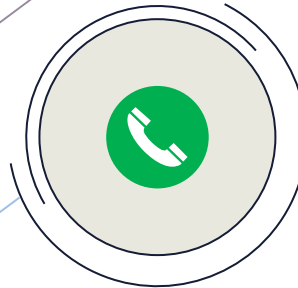
Lines of succession

Know who will step up in case an individual is incapacitated



Contact information

Have comprehensive contact information and emergency contacts

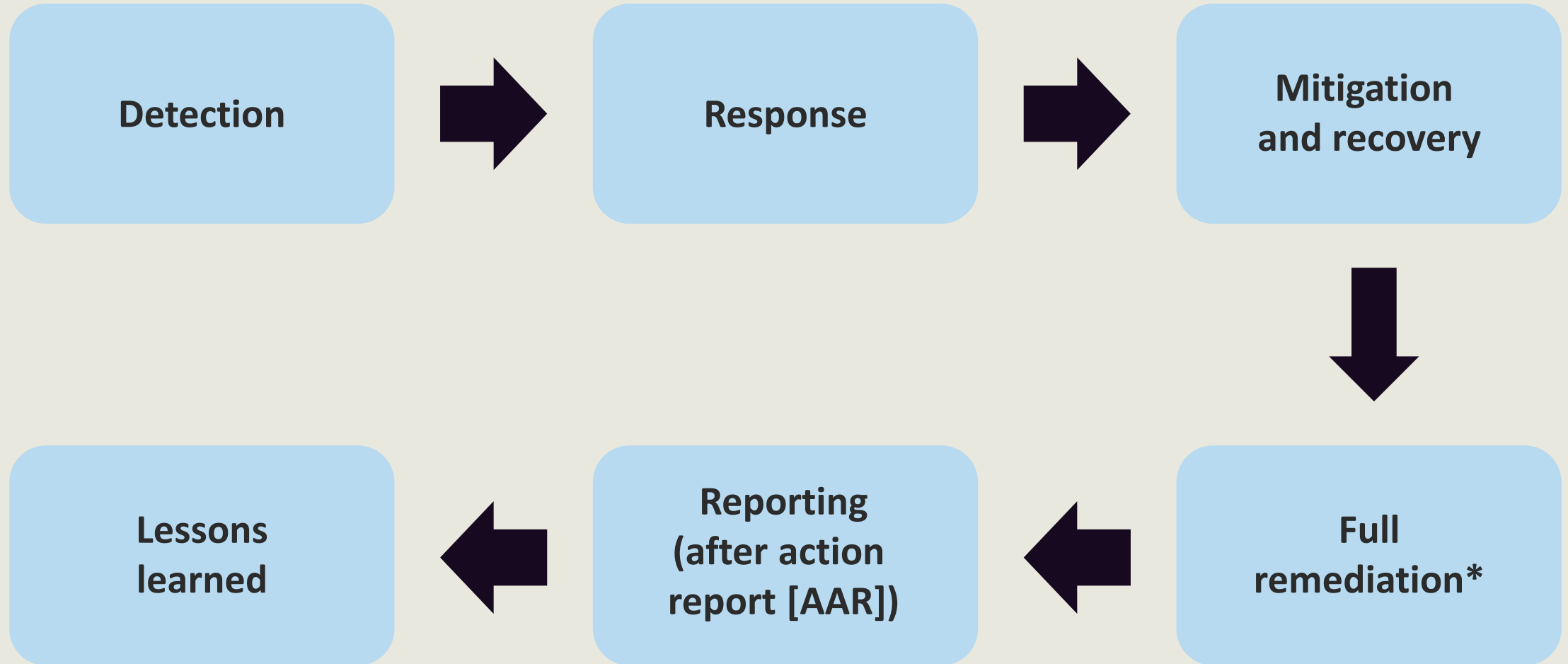


PERSONNEL IN THE DR PROCESS

- Most large organizations have a separate department or third-party vendor that supplements HR and legal to offer emergency management, counseling, and personal duress
- Arrangements should be made to deal with post-traumatic stress and other mental health challenges that arise after a catastrophic event
- Disaster recovery must be addressed in security training and awareness programs
- Accommodations should be made to temporarily or permanently replace key roles and responsibilities in contingency planning



DISASTER RECOVERY PLANNING LIFE CYCLE



DRP PERSONNEL WITH RACI CHARTS

R – Responsible **A** – Accountable **C** – Consulted **I** – Informed

	GRC* department	Legal department	Security team	IT operations
Establish the continuity requirements	R/A	C	C	I
Build the governance scheme	R/A	C	C	I
Assess recovery sites	A	I	R	R
Build the plan	I	I	A/R	R
Conduct tests and exercises	I	I	C	A/R

**GRC – Governance, Risk, and Compliance*

A person in a blue shirt is shown from the side, holding a black walkie-talkie to their mouth. The background is blurred, suggesting an outdoor setting. A thick pink diagonal line separates the image from the text on the right.

DISASTER COMMUNICATION PLANS

- A disaster recovery communication plan conveys the necessary tasks for sharing information with employees, contractors, customers, and other core stakeholders during and after a catastrophic event
- This information must be stored redundantly and in various formats – not just digitized on a single disk or database

DISASTER RECOVERY COMMUNICATION MODES

- Telephone land lines
- Voice over Internet Protocol (VoIP) phones
- Cellular phones
- Two-way radios and satellite phones
- Citizen band radios (CB)
- Short wave radios
- The U.S. has a product called “Rapid Radio” that piggybacks on existing towers

EMERGENCY COMMUNICATION PLANNING

01

Preserve current contact information data backups

02

Assemble a disaster communication team

03

Collect updated emergency contact information

04

Inform all internal and external stakeholders

05

Determine the communication strategies

06

Practice and rehearse various scenarios

ASSESSING THE DISASTER RECOVERY PLANS

- Assessment of the disaster recovery plan should begin with making sure that the **executive management or steering committee has approved the plan** and all elements
- Feedback and changes should be implemented in an iterative manner
- A solid plan will have senior management review and sign off on a regular basis
- This ensures that a particular role is ultimately responsible for due diligence and due care of the DRP



ASSESSING THE DISASTER RECOVERY PLANS



- The DRP should **follow a standardized, proven, and logical format**
- There must be a concise and well-organized approach to the recovery plans
- The table of contents should follow a logical path for the plan, assembling the teams, categorizing events, and executing recovery steps, etc.
- This document should be one of the most well constructed plans that the organization has based on the value to continuity of operations



ASSESSING THE DISASTER RECOVERY PLANS

- **The recovery team leaders should be evaluated and retrained on a regular basis**
- Identify the individual that supervises the recovery team leaders:
 - CIO, CISO, CEO, etc.
- Every element of the recovery plan must have a proven team leader and members who are capable to develop, maintain, and execute the plan in an emergency

ASSESSING THE DISASTER RECOVERY PLANS

- Recovery teams must perform regular gap analysis to **assure that any new or changed critical business processes are included in the plan**
- To be effective, managers must know exactly what processes need to be recovered, in the right timeframes, and all dependencies
- For example, recent challenges with the supply chains will force security professionals to reassess metrics such as mean time to respond (MTTR) and its effect on the DRP



ASSESSING THE DISASTER RECOVERY PLANS



- **The DRP should be as "event neutral" as possible**
- Since planners cannot develop a detailed scheme for every possible scenario, there should be a macro approach when feasible
- Scenarios such as loss of personnel, communication, data, and facilities should be addressed for a wide variety of negative events
- **Ultimately the DRP assessment will come from the lessons learned aspect of AAR**

Disaster Recovery Site Strategies

Recovery strategy	Recovery time	Advantages	Disadvantages
Commercial hot site	24 to 48 hours	• Best recovery time • Easiest to implement as equipment, application software, data, and OS are in place • Easy to test at any point in time • The best solution that is available to support on-going operations	• Most expensive options duplicate equipment and software plus ongoing version control issues • Ongoing communication costs to duplicate data very high • Term of the agreement can limit the duration of use • If you are not the "most important customer" you could be bumped
Internal hot	1 to 12 Hours	• Best recovery time • Easiest to implement as equipment, application software, data, and OS are in place • Easy to test at any point in time • The best solution that is available to support on-going operations	• Most expensive options duplicate equipment and software plus ongoing version control issues • Ongoing communication costs to duplicate data very high
Warm site	24 to 48 hours	• Moderately priced • Basic infrastructure is in place to support recovery operations • Ability to pre-stage delivery and implementing of the necessary hardware, application software, OS software, data, and communications	• Not easy to test • Recovery time is longer than with hot site and is controlled by the time to locate and restore application • Facility equipment may not be exactly what is required – once the recovery begins, delays may occur because of equipment, software, or staffing shortfalls

Disaster Recovery Site Strategies

Recovery strategy	Recovery time	Advantages	Disadvantages
Mobile site	24 to 48 hours	• Moderately priced • Typically, can be in place for 36 to 72 hours • Can be placed in the "parking lot" adjacent to you impacted facility	• Recovery time typically is at least 2 to 5 days longer than a hot site • Access to your impacted facility may be hindered because of the event • A trailer may not be configured exactly as you need it
Cold site	72 plus hours	• Lowest cost solution • Basic infrastructure power, air, and communication are in place • Can rent the facility for a longer term at lower cost	• Longest recovery time • All equipment must be ordered, delivered, installed and made operational • Worst solution for supporting ongoing operations
Reciprocal agreement	12 to 48 hours	• Least costly solution • Better than no strategy	• Seldom works • Typically, in the same geographic area and a wide range disaster like an earthquake renders it of no use • No easy way to test
Cloud	0 to 24 hours	• Data and applications available immediately • Location independent • Easy to test	• Security • May not allow enough time for a daily cycle processing window

READ-THROUGH (PLAN REVIEW)



- The read-through (plan review) is where the business continuity plan (BCP) owner and business continuity team discuss the BCP
- This is a type of checklist test that is useful for training new members of a team, including the business function owner
- It is constructed from brainstorming, surveys, and questionnaires
- The goal is to create a baseline and then find gaps and inconsistencies within the plan or with the organization

TABLETOP TESTING

- Participants gather in a room to execute documented plan activities in a stress-free environment using visualization techniques
- Teams will use blueprints, topological diagrams, or computer modeling and graphics to effectively demonstrate whether team members know their duties in an emergency and if they need training
- This will find additional documentation errors, missing data, and inconsistencies across disaster and business continuity plans





WALKTHROUGH TESTING

- Is a planned but limited rehearsal of a possible incident designed to evaluate an organization's capability to manage that incident
- Provides opportunities to build and improve on the read-throughs and tabletop tests
- Should improve the organization's future responses and enhance relevant competences of participants
- Is often done by scheduling drills for each department or building separately without affecting operations

SIMULATION TESTING

- This more elaborate test/drill will utilize established business continuity resources, recovery sites, backup equipment, services from recovery vendors, communication, and transportation recovery modes
- It will determine if business continuity management procedures and resources function in a realistic scenario
- This may be the most elaborate test most commercial entities ever conduct
- It can require sending teams to alternate sites to restart technology as well as business functions





PARALLEL TESTING

- This elaborate exercise involves bringing the recovery site to a state of operational readiness, but maintaining a low level of operations at the primary site
- The staff are relocated, backup tapes are transferred, and operational readiness established in accordance with the DRP at the recovery site
- Operations at the primary site continue with a skeleton crew
- This will have a substantial impact on operations and may demand crisis actors and other external consultants

FULL-INTERRUPTION TESTING

- Operations are completely shut down at the primary site to fully emulate the disaster
- The value proposition of the organization ceases to be delivered
- The enterprise transfers to the recovery site in accordance with the disaster recovery plan (hot, warm, cold, cloud)
- This is a very thorough test, which is also expensive and typically cost-prohibitive
- It has the capacity to cause a major disruption of operations if the test fails





LESSONS LEARNED

- Lessons learned is the knowledge and wisdom gained from the process of conducting the test/drill, program, project, or exercise
- This information will also be included in the AAR post-disaster
- Formal sessions are usually held at the project close-out or near the completion of the initiative

LESSONS LEARNED

- Lessons learned should be recognized and documented at any point during the life cycle to
 - Share and use knowledge derived from an experience
 - Endorse the recurrence of positive outcomes
 - Prevent the recurrence of negative outcomes
- Although someone may be held ultimately responsible, the goal of AAR should NOT be blamestorming or scapegoating





COMMUNICATING TEST RESULTS

- Once the after-action reporting and lessons learned are documented, the results must be adequately communicated to a variety of internal and external stakeholders:
 - Team members
 - Boards, committees, and executives
 - Insurers
 - Regulators
 - Press and media
 - Public declarations (website)
 - Existing and potential strategic partners
 - Existing and potential customers/clients

COMMUNICATING TEST RESULTS

- Align the AAR reporting with security guidance, policies, standards, and guidelines
- Maintain a consistent reporting structure over the life cycle for improved results
- Purge outdated and obsolete communications and data from subsequent reporting
- Engage the report consumers and stakeholders regularly to get feedback for possible improvements





DRP TRAINING AND AWARENESS BEST PRACTICES

- Remember that there is no "one-size-fits-all" DRP training solution
- Define the precise training objectives at the outset
- Ensure that all internal stakeholders are included in the awareness
- Consider the importance of rotation of duties and dual operator principles with disaster recovery
- Prioritize and construct specific risk scenarios for exercises and training

DRP TRAINING AND AWARENESS BEST PRACTICES

- Run joint training and awareness seminars with other groups such as Security Operation Center (SOC), incident response teams, security guards, and facilities management
- Vary the modalities of training between computer-based, webinars, classroom tabletop sessions, workshops, live drills, and exercises
- Consider hiring crisis actors when more elaborate training and exercises is cost-prohibitive

